BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM

BÀI TẬP LỚN

TÊN HỌC PHẦN: NHẬP MÔN AN TOÀN, BẢO MẬT THÔNG TIN

ĐỀ TÀI: GỬI CV AN TOÀN CÓ KIỂM TRA IP

Giáo viên hướng dẫn: ThS. Lê Thị Thùy Trang

Stt	Mã sv	Họ và tên	Lớp
01	1871020066	Vũ Quốc Anh	CNTT 18-02
02	1871020234	Ngô Văn Hiếu	CNTT 18-02
03	1871020471	Phạm Anh Quân	CNTT 18 -02

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC ĐẠI NAM

BÀI TẬP LỚN

TÊN HỌC PHẦN: NHẬP MÔN AN TOÀN, BẢO MẬT THÔNG TIN

ĐỀ TÀI: GỬI CV AN TOÀN CÓ KIỂM TRA IP

STT	Mã Sinh Viên	Họ và Tên	Ngày Sinh	Điểm	
				Bằng Số	Bằng Chữ
1	1871020066	Vũ Quốc Anh	07/02/2006		
2	1871020234	Ngô Văn Hiếu	20/03/2006		
3	1871020471	Phạm Anh Quân	09/07/2006		

CÁN BỘ CHẤM THI

Hà Nội, năm 2026

LỜI NÓI ĐẦU

Trong thời đại chuyển đổi số, tuyển dụng trực tuyến đã trở thành một xu hướng phổ biến, giúp doanh nghiệp và ứng viên kết nối nhanh chóng, thuận tiện và tiết kiệm chi phí. Thông qua các website và nền tảng tuyển dụng, ứng viên có thể dễ dàng gửi hồ sơ xin việc (CV) đến nhà tuyển dụng ở bất kỳ đâu. Tuy nhiên, cùng với những lợi ích đó là nhiều thách thức về an toàn thông tin như đánh cắp dữ liệu, truy cập trái phép, giả mạo người dùng hoặc chỉnh sửa hồ sơ trong quá trình truyền tải và lưu trữ.

CV là tài liệu chứa nhiều thông tin cá nhân và nghề nghiệp quan trọng của ứng viên như họ tên, ngày sinh, địa chỉ, số điện thoại, email, trình độ học vấn, kinh nghiệm làm việc và các chứng chỉ chuyên môn. Nếu các thông tin này bị rò rỉ hoặc bị thay đổi, không chỉ ảnh hưởng đến quyền riêng tư của ứng viên mà còn gây thiệt hại về uy tín và hiệu quả tuyển dụng của doanh nghiệp. Vì vậy, việc xây dựng một hệ thống bảo mật cho quá trình gửi và quản lý CV là yêu cầu cần thiết trong các hệ thống tuyển dụng hiện nay.

Xuất phát từ thực tế đó, nhóm lựa chọn đề tài "Secure Recruitment Submission – Gửi CV an toàn có kiểm tra IP" nhằm nghiên cứu và xây dựng một giải pháp bảo mật cho quá trình gửi hồ sơ trực tuyến. Hệ thống áp dụng các kỹ thuật mật mã hiện đại như: Cơ chế mã hóa lai (Hybrid Encryption) sử dụng AES-256-GCM để mã hóa dữ liệu và RSA-2048 để bảo vệ khóa. Tính toàn vẹn của dữ liệu được đảm bảo thông qua Authentication Tag của thuật toán GCM, thay thế cho cơ chế băm SHA-256 truyền thống. Đồng thời, hệ thống thay thế việc kiểm tra địa chỉ IP tĩnh bằng cơ chế xác thực Token an toàn hơn, kết hợp quản lý Metadata, ghi Audit Log ẩn danh và cơ chế Expire Time nhằm nâng cao tối đa mức độ an toàn của dữ liệu.

Thông qua đề tài, nhóm mong muốn vận dụng các kiến thức đã học về an toàn thông tin, mật mã học và phát triển phần mềm để xây dựng một mô hình hệ thống có tính ứng dụng thực tế. Đồng thời, đề tài cũng góp phần nâng cao nhận thức về tầm quan trọng của việc bảo vệ dữ liệu cá nhân trong môi trường tuyển dụng trực tuyến.

Mặc dù đã cố gắng nghiên cứu và hoàn thiện báo cáo, do kiến thức và thời gian thực hiện còn hạn chế nên khó tránh khỏi những thiếu sót. Nhóm rất mong nhận được những ý kiến đóng góp của thầy/cô và các bạn để báo cáo được hoàn thiện hơn.

BẢNG CÁC TỪ VIẾT TẮT

(Nếu có)

STT	TỪ VIẾT TẮT	VIẾT ĐẦY ĐỦ
1		
2		

MỤC LỤC (TỰ ĐỘNG)

CHƯƠNG I. GIỚI THIỆU 10

1.Giới thiệu đề tài 10

a) Xu hướng tuyển dụng trực tuyến 10

b) Rủi ro khi gửi CV 10

c) Tầm quan trọng của bảo mật 10

2.Mục tiêu đề tài 10

a) Bảo vệ thông tin ứng viên 10

b) Xác thực người gửi 10

c) Kiểm soát quyền truy cập 11

d) Đảm bảo tính toàn vẹn dữ liệu 11

e) Nâng cao tính an toàn của hệ thống 11

f) Hướng tới ứng dụng thực tế 11

3.Bối cảnh bài toán 11

a) Quy trình tuyển dụng trực tuyến *11*

b) Mô tả quy trình *12*

4. Threat Model (Mô hình mối đe dọa) 14

5.Thực trạng an toàn thông tin trong tuyển dụng trực tuyến 14

1. Tuyển dụng trực tuyến phát triển mạnh *15*

2. CV chứa nhiều thông tin quan trọng *15*

3. Tin tặc thường nhắm vào hệ thống tuyển dụng *15*

4. Hậu quả của việc rò rỉ dữ liệu *15*

6.Các thông tin cần được bảo vệ trong CV 16

7.Các yêu cầu bảo mật của hệ thống 18

1. Confidentiality (Tính bảo mật) *18*

2. Integrity (Tính toàn vẹn) *19*

3. Availability (Tính sẵn sàng) *19*

4. Authentication (Xác thực) *19*

5. Authorization (Phân quyền) *20*

6. Accountability (Khả năng truy vết) *20*

CHƯƠNG II.CƠ SỞ LÝ THUYẾT 22

1.Mã hóa dữ liệu (Data Encryption) 22

a) Encryption (Mã hóa) *22*

b) Decryption (Giải mã) *23*

c) Khóa bí mật (Secret Key) *23*

d) Khóa công khai (Public Key) *23*

e) So sánh hai phương pháp *24*

2. Xác thực tính toàn vẹn bằng cơ chế AEAD (GCM Tag) 24

a) Quy trình kiểm tra Hash *24*

b) SHA-256 ..... *25*

c) So sánh Hash *27*

3.Token xác thực (Authentication Token) 28

a) Mục đích sử dụng Token *28*

b) Session Token *28*

c) JWT (JSON Web Token) *28*

d) OTP (One-Time Password) *29*

4.Kiểm tra địa chỉ IP 30

4.1. Vai trò của việc kiểm tra IP *30*

4.2. Ưu điểm của kiểm tra IP *30*

4.3. Hạn chế của kiểm tra IP *31*

4.4. Vì sao không nên chỉ sử dụng IP? *31*

5.Metadata trong hệ thống tuyển dụng 31

a) Các thành phần Metadata *32*

b) Vai trò của Metadata trong hệ thống *33*

CHƯƠNG III.PHÂN TÍCH YÊU CẦU 35

1.Chức năng của hệ thống 35

a) Chức năng của Ứng viên *35*

b) Chức năng của Hệ thống *35*

c) Chức năng của Nhà tuyển dụng *36*

2.Use Case của hệ thống 38

a) Các tác nhân (Actors) *38*

b) Các chức năng chính *39*

3.Luồng xử lý Upload CV 41

a) Chi tiết từng bước *42*

4.Luồng xử lý Download CV 43

a) Chi tiết từng bước *43*

CHƯƠNG IV.GIẢI PHÁP BẢO MẬT 45

1.Xác thực nhiều lớp (Multi-Factor Authentication) 45

Các lớp xác thực của hệ thống 45

1. Username (Tên đăng nhập) *45*

2. Password (Mật khẩu) *45*

3. Token *45*

4. Kiểm tra địa chỉ IP *45*

2. Cơ chế Mã hóa lai (Hybrid Encryption) bằng AES-GCM và RSA 47

3. Kiểm tra tính toàn vẹn bằng Authentication Tag (Chống Tampering) 49

4.Metadata trong hệ thống 50

a) Các trường Metadata 50

b) Ví dụ Metadata 51

c) Vai trò của Metadata 52

5.Cơ chế hết hạn (Expire Time) 53

6. Phân tích mã nguồn 54

CHƯƠNG V.DEMO HỆ THỐNG 56

1.Giao diện Upload CV 56

2. Các thành phần trên giao diện 56

3.Kết quả Upload thành công 58

a) Thông tin hiển thị *59*

4.Giao diện Download 60

a*) Các bước xử lý* 61

CHƯƠNG VI. KIỂM THỬ HỆ THỐNG 63

1.Test Case 63

2.Kết quả kiểm thử 65

a) Kết quả đạt được 65

CHƯƠNG VII. ĐÁNH GIÁ MỨC ĐỘ KẾ THỪA VÀ NÂNG CẤP 66

CHƯƠNG VIII. ĐÁNH GIÁ VÀ KẾT LUẬN 67

1.Ưu điểm của hệ thống 67

a) Những ưu điểm nổi bật *67*

b) Đánh giá chung *68*

2.Hạn chế của hệ thống 68

a) Các hạn chế *68*

b) Hướng cải thiện *69*

3.Kết luận và hướng phát triển 69

Tài liệu tham khảo 71

CHƯƠNG I. GIỚI THIỆU

1.Giới thiệu đề tài

a) Xu hướng tuyển dụng trực tuyến

- Doanh nghiệp ngày càng ưu tiên tuyển dụng qua các nền tảng trực tuyến.
- Ứng viên có thể gửi CV mọi lúc, mọi nơi thông qua website hoặc ứng dụng.
- Hình thức này giúp tiết kiệm thời gian, chi phí và mở rộng cơ hội việc làm.

b) Rủi ro khi gửi CV

- CV chứa nhiều thông tin cá nhân như họ tên, số điện thoại, email, địa chỉ và kinh nghiệm làm việc.
- Dữ liệu có thể bị đánh cắp, sửa đổi hoặc truy cập trái phép trong quá trình truyền tải.
- Tin tặc có thể lợi dụng thông tin để lừa đảo hoặc giả mạo danh tính.

c) Tầm quan trọng của bảo mật

- Đảm bảo tính **bí mật** của thông tin ứng viên.
- Bảo vệ tính **toàn vẹn** của CV, tránh bị chỉnh sửa.
- Xác thực người gửi và hạn chế truy cập từ các địa chỉ IP không được phép.
- Tăng độ tin cậy và an toàn cho hệ thống tuyển dụng.

2.Mục tiêu đề tài

- Mục tiêu chung: Xây dựng hệ thống **Secure Recruitment Submission** giúp ứng viên gửi CV một cách an toàn, bảo vệ dữ liệu cá nhân và ngăn chặn các truy cập trái phép trong quá trình tuyển dụng trực tuyến.

- Mục tiêu cụ thể:

a) Bảo vệ thông tin ứng viên

- Mã hóa CV trước khi lưu trữ và truyền tải.
- Bảo vệ các thông tin cá nhân như họ tên, email, số điện thoại.
- Hạn chế nguy cơ rò rỉ hoặc đánh cắp dữ liệu.

b) Xác thực người gửi

- Kiểm tra tài khoản đăng nhập của ứng viên.

- Xác minh danh tính trước khi cho phép gửi CV.
- Ngăn chặn việc giả mạo hoặc gửi hồ sơ trái phép.

c) Kiểm soát quyền truy cập

- Chỉ nhà tuyển dụng được cấp quyền mới có thể xem CV.
- Phân quyền rõ ràng giữa ứng viên và nhà tuyển dụng.
- Hạn chế truy cập trái phép vào dữ liệu.

d) Đảm bảo tính toàn vẹn dữ liệu

- Kiểm tra CV có bị chỉnh sửa trong quá trình truyền tải hay không.
- Sử dụng hàm băm (Hash) để xác minh dữ liệu.
- Đảm bảo nhà tuyển dụng nhận đúng nội dung ứng viên đã gửi.

e) Nâng cao tính an toàn của hệ thống

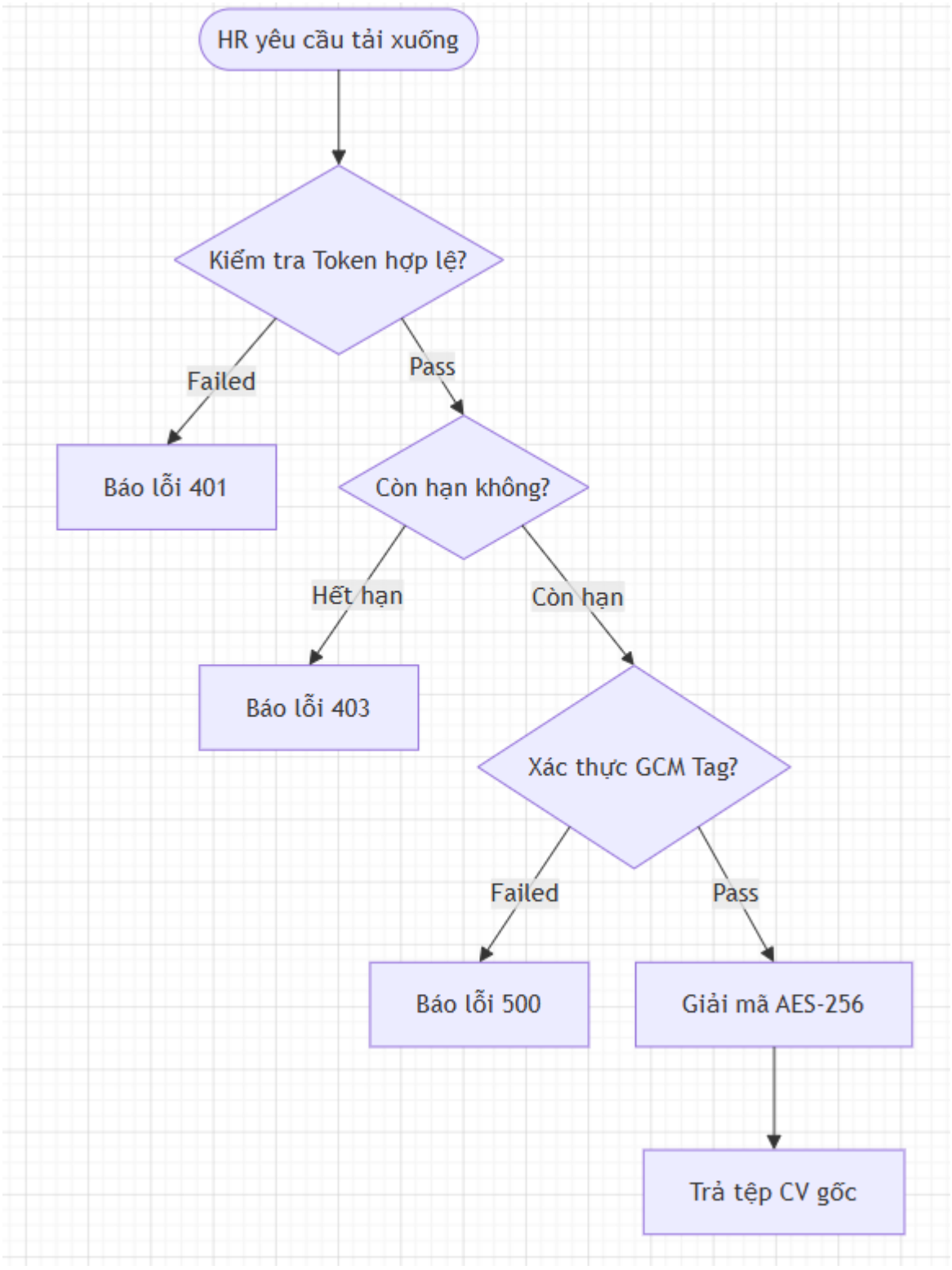
- Ghi nhật ký hoạt động để theo dõi các lần đăng nhập.
- Hỗ trợ phát hiện các hành vi bất thường.

f) Hướng tới ứng dụng thực tế

- Có thể triển khai trên website tuyển dụng.
- Dễ mở rộng thêm xác thực hai lớp (2FA), OTP hoặc AI phát hiện tấn công.
- Góp phần nâng cao độ tin cậy của hệ thống tuyển dụng.

3.Bối cảnh bài toán

a) Quy trình tuyển dụng trực tuyến



b) Mô tả quy trình

Bước 1: Ứng viên

- Đăng nhập vào hệ thống tuyển dụng.
- Chuẩn bị và tải lên CV.
- Gửi hồ sơ ứng tuyển đến doanh nghiệp.

Bước 2: Website tuyển dụng

- Tiếp nhận yêu cầu từ ứng viên.
- Kiểm tra thông tin đăng nhập.
- Chuyển dữ liệu đến máy chủ để xử lý.

Bước 3: Máy chủ

- Mã hóa CV trước khi lưu trữ.
- Tạo mã Hash để kiểm tra tính toàn vẹn.
- Lưu trữ dữ liệu trong cơ sở dữ liệu.

Bước 4: Nhà tuyển dụng

- Đăng nhập bằng tài khoản được cấp quyền.
- Hệ thống xác thực quyền truy cập.
- Giải mã và xem nội dung CV.
- Đánh giá hồ sơ của ứng viên.

- Những vấn đề có thể xảy ra

- CV bị đánh cắp trong quá trình truyền tải.
- Hacker truy cập trái phép vào máy chủ.
- Dữ liệu bị chỉnh sửa hoặc thay thế.
- Người không có quyền vẫn có thể xem CV.
- Rò rỉ thông tin cá nhân của ứng viên.

- Giải pháp của đề tài

- Mã hóa CV trước khi lưu trữ.
- Kiểm tra Hash để đảm bảo toàn vẹn dữ liệu.
- Phân quyền người dùng, chỉ nhà tuyển dụng được phép xem CV.

4. Threat Model (Mô hình mối đe dọa)

- Để thiết kế hệ thống an toàn, nhóm đã xác định mô hình mối đe dọa (Threat Model) như sau:

- **Tài sản cần bảo vệ:** Tệp tin CV của ứng viên (chứa thông tin cá nhân, liên lạc, học vấn) và siêu dữ liệu (Metadata) đi kèm.

- **Người dùng hợp lệ:**

- Ứng viên: Người tải CV lên hệ thống.
- Nhà tuyển dụng (HR): Người có Token hợp lệ để tải và xem CV.

- **Tác nhân tấn công giả định:**

- Hacker từ bên ngoài đánh chặn dữ liệu trên đường truyền.
- Hacker xâm nhập được vào máy chủ lưu trữ thư mục uploaded_files.
- Người nội bộ (hoặc ứng viên khác) cố tình đoán đường link để tải CV của người khác.

- **Các nguy cơ bảo mật:**

- Lộ lọt thông tin CV (Mất tính bí mật).
- Nội dung CV bị sửa đổi trái phép (Tampering - Mất tính toàn vẹn).
- Tấn công phát lại (Replay Attack) gửi nhiều hồ sơ rác.
- Giả mạo quyền truy cập (Sai Token).

- **Các giả định và giới hạn của hệ thống:**

- Giả định rằng máy chủ ứng dụng (Flask) không bị chiếm quyền điều khiển hoàn toàn (Root access).
- Giả định rằng Nhà tuyển dụng bảo quản an toàn mật khẩu mở khóa private_key.pem.

5.Thực trạng an toàn thông tin trong tuyển dụng trực tuyến

- **Thực trạng hiện nay:** Trong thời đại chuyển đổi số, các doanh nghiệp ngày càng ưu tiên tuyển dụng trực tuyến thông qua website, ứng dụng hoặc các nền tảng việc làm. Điều này giúp quá trình tuyển dụng diễn ra nhanh chóng, thuận tiện và tiết kiệm chi phí. Tuy nhiên, cùng với sự phát triển đó là nhiều nguy cơ mất an toàn thông tin.

1. Tuyển dụng trực tuyến phát triển mạnh

- Doanh nghiệp đăng tuyển và tiếp nhận hồ sơ hoàn toàn qua Internet.
- Ứng viên có thể gửi CV ở bất kỳ đâu và bất kỳ thời điểm nào.
- Khối lượng dữ liệu được trao đổi mỗi ngày rất lớn.

2. CV chứa nhiều thông tin quan trọng

- Họ và tên.
- Ngày tháng năm sinh.
- Số điện thoại và địa chỉ email.
- Địa chỉ nơi ở.
- Trình độ học vấn và kinh nghiệm làm việc.
- Chứng chỉ, kỹ năng và các thông tin cá nhân khác.

Đây đều là những dữ liệu có giá trị, nếu bị lộ có thể bị lợi dụng để giả mạo danh tính hoặc thực hiện các hành vi lừa đảo.

3. Tin tặc thường nhắm vào hệ thống tuyển dụng

- Tấn công để đánh cắp cơ sở dữ liệu ứng viên.
- Khai thác lỗ hổng bảo mật của website.
- Chiếm quyền truy cập tài khoản quản trị.
- Chèn mã độc hoặc thay đổi dữ liệu trong hệ thống.

4. Hậu quả của việc rò rỉ dữ liệu

Đối với ứng viên

- Mất quyền riêng tư.
- Bị lừa đảo qua email hoặc điện thoại.
- Nguy cơ bị đánh cắp danh tính.

Đối với doanh nghiệp

- Mất uy tín và niềm tin của ứng viên.
- Thiệt hại về tài chính và pháp lý.
- Gián đoạn hoạt động tuyển dụng.

- Kết luận

Để giảm thiểu các nguy cơ trên, hệ thống tuyển dụng cần áp dụng các giải pháp như:

- Mã hóa dữ liệu CV trước khi lưu trữ và truyền tải.
- Xác thực người dùng và phân quyền truy cập.
- Sử dụng hàm băm (Hash) để đảm bảo tính toàn vẹn của dữ liệu.
- Ghi nhật ký và giám sát các hoạt động truy cập nhằm phát hiện sớm các dấu hiệu bất thường.

6.Các thông tin cần được bảo vệ trong CV

- Tại sao cần bảo vệ thông tin trong CV?

CV (Curriculum Vitae) là tài liệu quan trọng phản ánh thông tin cá nhân, trình độ học vấn và kinh nghiệm làm việc của ứng viên. Nếu các thông tin này bị rò rỉ hoặc đánh cắp, ứng viên có thể bị giả mạo danh tính, lừa đảo hoặc xâm phạm quyền riêng tư. Vì vậy, hệ thống tuyển dụng cần có cơ chế bảo mật để đảm bảo tính bí mật và an toàn của dữ liệu.

- Các thông tin quan trọng cần được bảo vệ

1. Họ và tên

- Xác định danh tính của ứng viên.
- Có thể bị lợi dụng để giả mạo hồ sơ hoặc thực hiện các hành vi lừa đảo.

2. Ngày sinh

- Là thông tin định danh quan trọng.
- Thường được sử dụng trong quá trình xác minh tài khoản hoặc thông tin cá nhân.

3. Địa chỉ Email

- Là kênh liên lạc chính giữa ứng viên và nhà tuyển dụng.
- Nếu bị lộ, có thể nhận thư rác, email giả mạo hoặc bị tấn công lừa đảo (Phishing).

4. Số điện thoại

- Dùng để liên hệ phỏng vấn và xác nhận thông tin.

- Có nguy cơ bị làm phiền, quảng cáo hoặc lừa đảo qua điện thoại.

5. Địa chỉ cư trú

- Thể hiện nơi sinh sống của ứng viên.
- Nếu bị lộ có thể ảnh hưởng đến quyền riêng tư và an toàn cá nhân.

6. Kinh nghiệm làm việc

- Bao gồm thông tin về công ty đã làm, vị trí công việc và thành tích đạt được.
- Đây là dữ liệu có giá trị và cần được bảo vệ khỏi việc sao chép hoặc chỉnh sửa.

7. Bằng cấp

- Chứng minh trình độ học vấn của ứng viên.
- Nếu bị thay đổi có thể ảnh hưởng đến quá trình tuyển dụng.

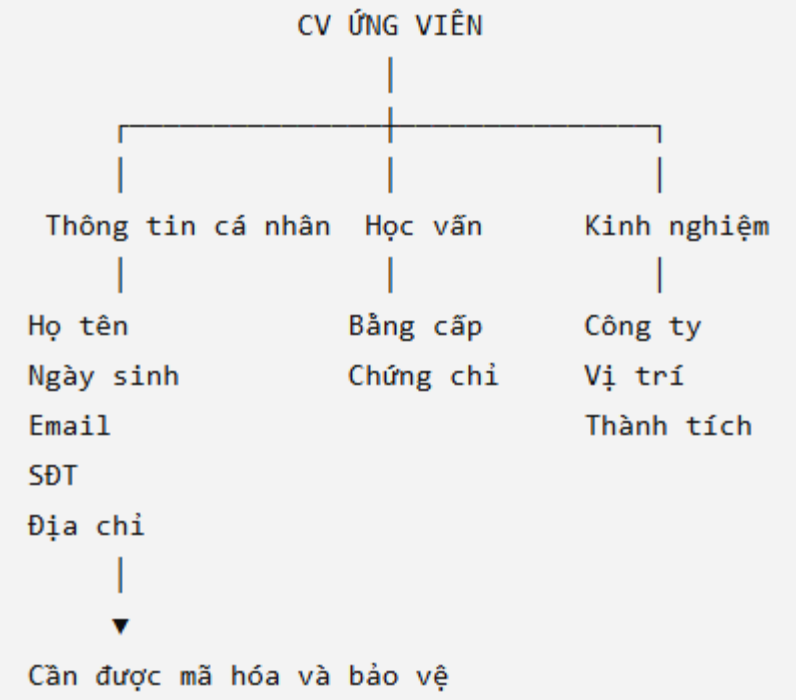
8. Chứng chỉ

- Bao gồm các chứng chỉ ngoại ngữ, tin học và chuyên môn.
- Cần được đảm bảo tính chính xác và toàn vẹn để tránh giả mạo.

- **Biện pháp bảo vệ các thông tin trên**

- Mã hóa CV trước khi lưu trữ và truyền tải.
- Chỉ người dùng được cấp quyền mới có thể xem nội dung CV.
- Sử dụng hàm băm (Hash) để phát hiện nếu dữ liệu bị chỉnh sửa.
- Ghi nhật ký truy cập để theo dõi và phát hiện các hành vi bất thường.

- **Hình minh họa**



7.Các yêu cầu bảo mật của hệ thống

- Mô hình bảo mật của hệ thống

Để xây dựng một hệ thống gửi CV trực tuyến an toàn, đề tài áp dụng các nguyên tắc bảo mật theo mô hình CIA (Confidentiality – Integrity – Availability) kết hợp với các cơ chế Authentication, Authorization và Accountability. Đây là những yêu cầu cốt lõi trong hầu hết các hệ thống thông tin hiện đại.

1. Confidentiality (Tính bảo mật)

Mục tiêu: Đảm bảo chỉ những người được cấp quyền mới có thể xem thông tin.

Ý nghĩa

- Bảo vệ CV và thông tin cá nhân của ứng viên.
- Ngăn chặn việc đọc hoặc sao chép dữ liệu trái phép.
- Giữ bí mật dữ liệu trong quá trình truyền và lưu trữ.

Giải pháp áp dụng

- Mã hóa CV trước khi lưu.

- Sử dụng kết nối an toàn.
- Phân quyền truy cập cho từng người dùng.

2. Integrity (Tính toàn vẹn)

Mục tiêu: Đảm bảo dữ liệu không bị thay đổi trái phép.

Ý nghĩa

- CV phải giữ nguyên nội dung từ khi ứng viên gửi đến khi nhà tuyển dụng xem.
- Phát hiện mọi hành vi sửa đổi dữ liệu.

Giải pháp áp dụng

- Sử dụng hàm băm (Hash).
- So sánh giá trị Hash trước và sau khi truyền.

3. Availability (Tính sẵn sàng)

Mục tiêu: Hệ thống luôn hoạt động khi người dùng cần.

Ý nghĩa

- Ứng viên có thể gửi CV bất cứ lúc nào.
- Nhà tuyển dụng có thể truy cập hồ sơ nhanh chóng.
- Hạn chế thời gian gián đoạn của hệ thống.

Giải pháp áp dụng

- Sao lưu dữ liệu định kỳ.
- Bảo trì hệ thống thường xuyên.
- Giám sát để phát hiện và xử lý sự cố kịp thời.

4. Authentication (Xác thực)

Mục tiêu: Xác minh đúng danh tính người sử dụng.

Ý nghĩa

- Đảm bảo người gửi đúng là ứng viên.
- Đảm bảo người xem đúng là nhà tuyển dụng.

Giải pháp áp dụng

- Đăng nhập bằng tài khoản.
- Mật khẩu được băm (Hash).
- Có thể mở rộng thêm OTP hoặc xác thực hai lớp (2FA).

5. Authorization (Phân quyền)

Mục tiêu: Mỗi người dùng chỉ được thực hiện các chức năng được cấp phép.

Ví dụ

- Ứng viên chỉ được tải lên và quản lý CV của mình.
- Nhà tuyển dụng chỉ được xem các CV được cấp quyền.
- Quản trị viên quản lý toàn bộ hệ thống.

6. Accountability (Khả năng truy vết)

Mục tiêu: Ghi nhận mọi hoạt động trong hệ thống.

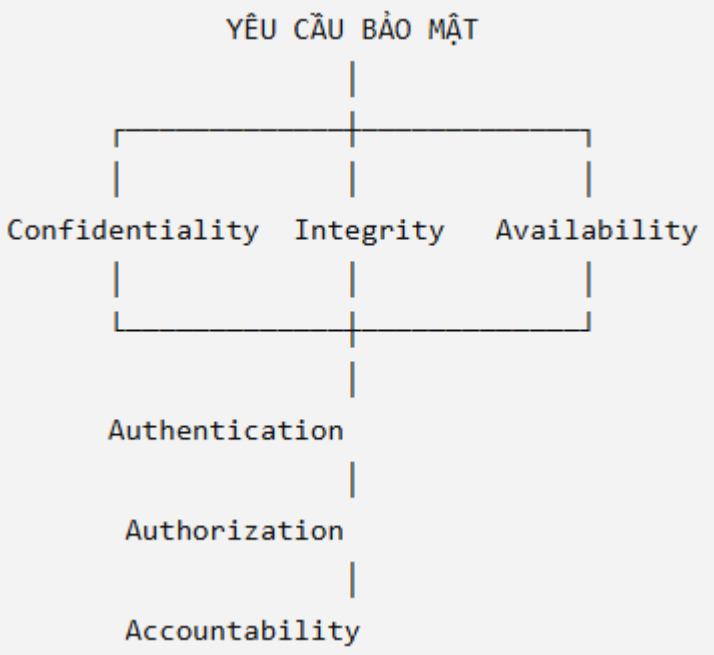
Ý nghĩa

- Theo dõi lịch sử đăng nhập.
- Ghi lại thời gian gửi và xem CV.
- Hỗ trợ điều tra khi xảy ra sự cố bảo mật.

Giải pháp áp dụng

- Ghi nhật ký (Log).
- Theo dõi các hành động quan trọng của người dùng.

Tóm tắt mô hình bảo mật



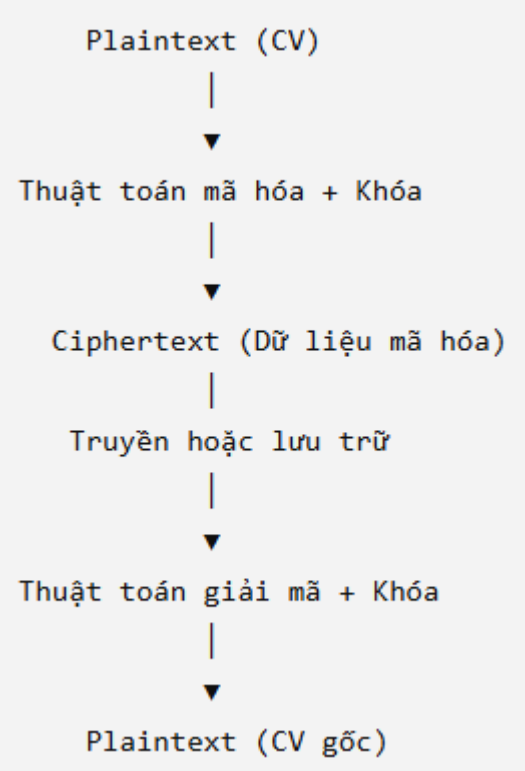
CHƯƠNG II.CƠ SỞ LÝ THUYẾT

1.Mã hóa dữ liệu (Data Encryption)

- Khái niệm mã hóa dữ liệu

Mã hóa dữ liệu (Encryption) là quá trình chuyển đổi dữ liệu gốc (Plaintext) thành dữ liệu đã mã hóa (Ciphertext) bằng một thuật toán và khóa mã hóa. Chỉ người sở hữu khóa phù hợp mới có thể giải mã để đọc nội dung.

- Quy trình mã hóa



a) Encryption (Mã hóa)

- Chuyển dữ liệu gốc thành dữ liệu không thể đọc được.
- Bảo vệ thông tin trong quá trình truyền và lưu trữ.
- Ngăn chặn người không có quyền truy cập.

Ví dụ

```
CV.pdf
↓
Mã hóa
↓
8F3A92B5D7A6...
```

b) Decryption (Giải mã)

- Chuyển dữ liệu đã mã hóa về dạng ban đầu.
- Chỉ thực hiện được khi có khóa giải mã chính xác.
- Nhà tuyển dụng được cấp quyền mới có thể xem CV.

c) Khóa bí mật (Secret Key)

- Dùng trong mã hóa đối xứng.
- Một khóa dùng cho cả mã hóa và giải mã.
- Tốc độ nhanh, phù hợp mã hóa tệp lớn.

- Ví dụ thuật toán

- AES
- DES
- 3DES

d) Khóa công khai (Public Key)

- Dùng trong mã hóa bất đối xứng.
- Public Key dùng để mã hóa.
- Private Key dùng để giải mã.

Ví dụ thuật toán

- RSA
- ECC

e) So sánh hai phương pháp

Mã hóa đối xứng	**Mã hóa bất đối xứng**
Một khóa	Hai khóa
Tốc độ nhanh	Chậm hơn
Phù hợp dữ liệu lớn	Phù hợp trao đổi khóa
Ví dụ: AES	Ví dụ: RSA

- Vai trò trong đề tài

- Mã hóa CV trước khi lưu trữ.
- Bảo vệ thông tin ứng viên.
- Chỉ người có quyền mới giải mã được.
- Tăng tính bảo mật cho hệ thống tuyển dụng.

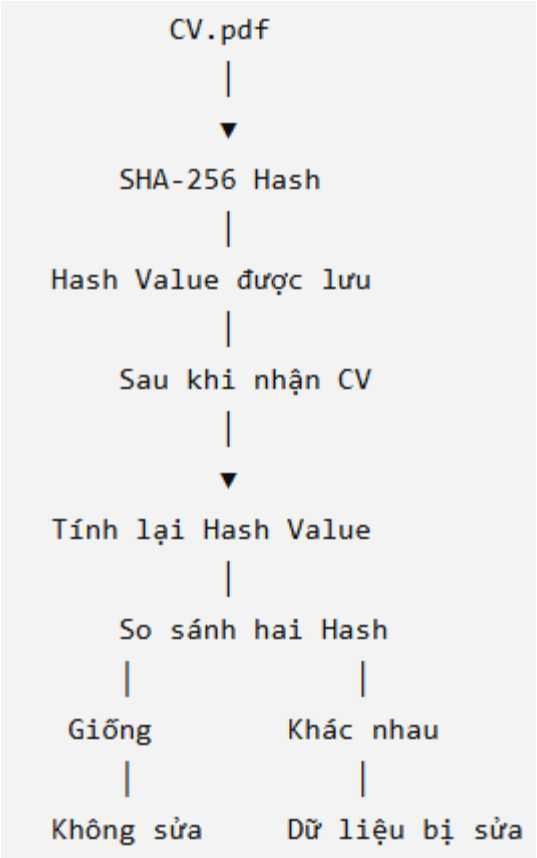
2. Xác thực tính toàn vẹn bằng cơ chế AEAD (GCM Tag)

- Khái niệm Hash Function

+ Hash Function là thuật toán chuyển đổi dữ liệu có độ dài bất kỳ thành một chuỗi ký tự có độ dài cố định gọi là **Hash Value** hoặc **Message Digest**.

+ Hash **không dùng để mã hóa**, mà dùng để kiểm tra xem dữ liệu có bị thay đổi hay không.

a) Quy trình kiểm tra Hash



b) SHA-256

SHA-256 là một thuật toán băm thuộc họ SHA-2.

- Đặc điểm

- Độ dài kết quả luôn là **256 bit (64 ký tự Hex)**.
- Không thể khôi phục dữ liệu gốc từ giá trị Hash.
- Chỉ cần thay đổi một ký tự nhỏ, kết quả Hash sẽ thay đổi hoàn toàn.
- Được sử dụng rộng rãi trong bảo mật và xác minh dữ liệu.

- **Ví dụ**

```
CV.pdf
↓

SHA-256

↓

5d41402abc4b2a76b9719d911017c592...
```

- Nếu CV bị sửa chỉ một ký tự:

```
CV_new.pdf

↓

SHA-256

↓

91f7b2957d4b5f9d18e9...
```

c) So sánh Hash

Hash giống nhau	Hash khác nhau
Dữ liệu không thay đổi	Dữ liệu đã bị chỉnh sửa
Toàn vẹn	Không toàn vẹn

- Ứng dụng trong đề tài

- Tạo Hash ngay sau khi ứng viên tải CV lên.
- Lưu giá trị Hash cùng với dữ liệu.
- Khi nhà tuyển dụng mở CV, hệ thống tính lại Hash.
- Nếu hai giá trị trùng nhau → CV an toàn.
- Nếu khác nhau → Cảnh báo dữ liệu đã bị thay đổi.

- Lợi ích của Hash

- Phát hiện chỉnh sửa dữ liệu.
- Đảm bảo tính toàn vẹn.
- Hỗ trợ xác minh tính chính xác của CV.
- Tăng độ tin cậy của hệ thống.

- Thay vì sử dụng hàm băm (Hash Function) rời rạc như SHA-256 truyền thống, hệ thống nâng cấp sử dụng chế độ mã hóa **AES-GCM (Galois/Counter Mode)**. Đây là một dạng mã hóa có xác thực (AEAD - Authenticated Encryption with Associated Data).

- **Cơ chế hoạt động:** Trong quá trình mã hóa dữ liệu, thuật toán AES-GCM tự động tính toán và sinh ra một Authentication Tag (thẻ xác thực) đính kèm cùng dữ liệu đã mã hóa (Ciphertext).

- **Cơ chế phát hiện can thiệp (Tampering Check):**

- Khi nhà tuyển dụng tiến hành giải mã, hàm AES-GCM sẽ tính toán lại Tag từ Ciphertext nhận được.
- Nếu dữ liệu bị chỉnh sửa dù chỉ 1 byte trong quá trình lưu trữ hoặc truyền tải, Tag sẽ không khớp hoàn toàn.
- Hệ thống sẽ lập tức dừng quá trình giải mã, trả về lỗi HTTP 500 và ghi cảnh báo đỏ vào file audit_access.log để quản trị viên xử lý.

- **Lợi ích:** Cơ chế này cung cấp tính toàn vẹn và xác thực dữ liệu ngay trong quá trình giải mã, giúp tối ưu hiệu năng và tăng cường bảo mật so với việc băm rời rạc.

3.Token xác thực (Authentication Token)

- Khái niệm: Token xác thực là một chuỗi ký tự được hệ thống tạo ra sau khi người dùng đăng nhập thành công. Token đóng vai trò như "thẻ định danh", giúp hệ thống xác minh người dùng trong suốt phiên làm việc mà không cần nhập lại mật khẩu ở mỗi yêu cầu.

a) Mục đích sử dụng Token

- Xác thực danh tính người dùng.
- Duy trì trạng thái đăng nhập.
- Bảo vệ các chức năng quan trọng của hệ thống.
- Hạn chế truy cập trái phép.
- Tăng tính an toàn khi trao đổi dữ liệu.

b) Session Token

- **Đặc điểm**

- Được tạo sau khi người dùng đăng nhập.
- Lưu trên máy chủ (Server).
- Mỗi người dùng có một Session ID riêng.
- Hết hiệu lực khi đăng xuất hoặc hết thời gian sử dụng.

- **Ưu điểm**

- Dễ triển khai.
- An toàn vì dữ liệu phiên được lưu trên máy chủ.

- **Nhược điểm**

- Tiêu tốn bộ nhớ Server khi có nhiều người dùng.

c) JWT (JSON Web Token)

- JWT là một chuẩn xác thực phổ biến trong các hệ thống Web và Mobile.

- **Cấu trúc JWT**

```
Header
  ↓
Payload
  ↓
Signature
```

- Đặc điểm

- Không cần lưu Session trên Server.
- Có thể mang theo thông tin người dùng.
- Dễ tích hợp với API và ứng dụng di động.

- Ưu điểm

- Hiệu năng cao.
- Phù hợp với hệ thống phân tán.

- Nhược điểm

- Nếu Token bị lộ vẫn có thể bị lợi dụng cho đến khi hết hạn.

d) OTP (One-Time Password)

- OTP là mật khẩu chỉ sử dụng một lần.

- Có thể gửi qua

- SMS
- Email
- Ứng dụng xác thực (Google Authenticator...)

- Vai trò

- Xác minh danh tính người dùng.
- Bổ sung lớp bảo mật thứ hai (2FA).
- Giảm nguy cơ tài khoản bị chiếm quyền.

- Ứng dụng trong đề tài

- Hệ thống có thể sử dụng:

- Đăng nhập bằng tài khoản và mật khẩu.
- Session hoặc JWT để duy trì phiên đăng nhập.
- OTP khi cần xác minh tài khoản hoặc tăng cường bảo mật.

4.Kiểm tra địa chỉ IP

- Khái niệm địa chỉ IP

Địa chỉ IP (Internet Protocol Address) là địa chỉ định danh của mỗi thiết bị khi kết nối Internet hoặc mạng nội bộ. Hệ thống có thể sử dụng IP để nhận biết nguồn truy cập và tăng cường khả năng kiểm soát an ninh.

4.1. Vai trò của việc kiểm tra IP

a) Xác định nguồn truy cập

- Biết người dùng truy cập từ đâu.
- Ghi nhận địa chỉ IP trong nhật ký hệ thống.

b) Phát hiện truy cập bất thường

- Phát hiện nhiều lần đăng nhập thất bại.
- Cảnh báo khi đăng nhập từ IP lạ hoặc quốc gia khác.
- Hỗ trợ phát hiện hành vi tấn công.

c) Hạn chế truy cập trái phép

- Chỉ cho phép IP nằm trong danh sách tin cậy.
- Chặn IP có dấu hiệu tấn công hoặc gửi yêu cầu bất thường.
- Giảm nguy cơ dò mật khẩu và tấn công tự động.

4.2. Ưu điểm của kiểm tra IP

- Dễ triển khai.
- Giúp tăng cường bảo mật.
- Hỗ trợ theo dõi và điều tra sự cố.
- Có thể kết hợp với Firewall và hệ thống phát hiện xâm nhập.

4.3. Hạn chế của kiểm tra IP

- Người dùng có thể thay đổi IP khi sử dụng mạng khác.
- VPN hoặc Proxy có thể che giấu địa chỉ IP thật.
- Nhiều người có thể dùng chung một IP công cộng.
- IP động thay đổi theo thời gian.

4.4. Vì sao không nên chỉ sử dụng IP?

- Việc kiểm tra IP chỉ là một lớp bảo vệ, không đủ để xác thực người dùng.

Nếu chỉ dựa vào IP:

- Không xác minh được danh tính người truy cập.
- Có thể bị vượt qua bằng VPN hoặc Proxy.
- Không ngăn được việc sử dụng tài khoản bị đánh cắp.

- Vì việc kiểm tra IP tĩnh (IP Whitelist) tồn tại lỗ hổng chết người là dễ bị tấn công giả mạo (IP Spoofing) hoặc bị qua mặt bởi VPN/Proxy, nên đề tài này đã quyết định loại bỏ cơ chế xác thực bằng IP của phiên bản cũ. Thay vào đó, hệ thống được nâng cấp lên cơ chế cấp quyền bằng Token (Token-based Authentication). Nhà tuyển dụng bắt buộc phải truyền đúng Token hợp lệ qua tham số URL (?token=...) thì mới được Server cấp quyền giải mã và tải CV.

5.Metadata trong hệ thống tuyển dụng

- Metadata là gì?

Metadata là dữ liệu mô tả về dữ liệu. Đối với hệ thống gửi CV trực tuyến, metadata không chứa nội dung của CV mà lưu các thông tin quản lý giúp hệ thống xác định, theo dõi và bảo vệ tệp CV.

Ví dụ: Khi một ứng viên tải lên CV, ngoài tệp CV, hệ thống sẽ lưu thêm các thông tin như mã ứng viên, thời gian tải lên, thời gian hết hạn và các thông tin phục vụ xác thực.

a) Các thành phần Metadata

1. candidate_id

- Là mã định danh duy nhất của ứng viên.
- Dùng để phân biệt giữa các ứng viên.
- Liên kết CV với tài khoản người dùng.
- Giúp tìm kiếm và quản lý hồ sơ nhanh chóng.

Ví dụ

```
candidate_id = CAND000125
```

2. job_id

- Là mã của vị trí tuyển dụng.
- Xác định CV được gửi cho công việc nào.
- Một ứng viên có thể gửi nhiều CV cho nhiều vị trí khác nhau.

Ví dụ

```
job_id = JOB2026008
```

3. upload_time

- Thời điểm ứng viên tải CV lên hệ thống.
- Dùng để quản lý lịch sử nộp hồ sơ.
- Hỗ trợ sắp xếp và thống kê dữ liệu.

Ví dụ

```
03/07/2026
14:30:15
```

4. expire_time

- Thời điểm CV hoặc liên kết tải xuống hết hiệu lực.
- Sau thời gian này, hệ thống có thể từ chối truy cập hoặc yêu cầu tải lại.
- Giúp tăng cường bảo mật và giảm nguy cơ truy cập trái phép.

Ví dụ

```
10/07/2026
23:59:59
```

5. Nonce

Nonce (Number used once) là một giá trị ngẫu nhiên chỉ được sử dụng một lần.

Vai trò

- Chống tấn công Replay Attack.
- Đảm bảo mỗi yêu cầu gửi CV là duy nhất.
- Ngăn kẻ tấn công phát lại các yêu cầu cũ để đánh lừa hệ thống.

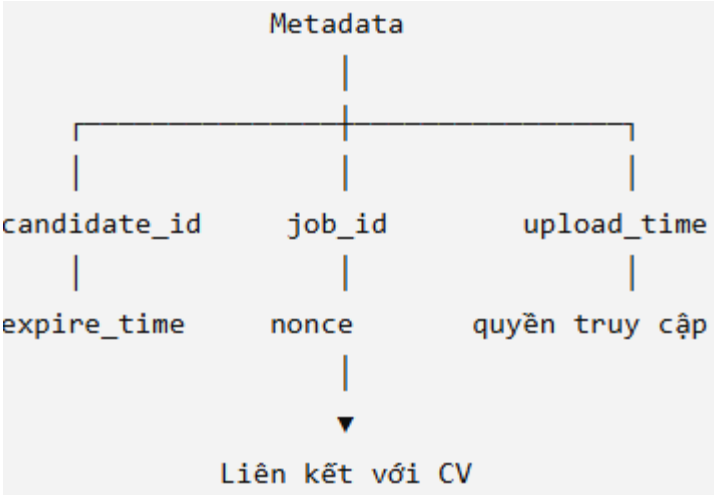
Ví dụ

```
Nonce = A8F4D29BC731
```

b) Vai trò của Metadata trong hệ thống

- Quản lý thông tin của từng CV.
- Hỗ trợ tìm kiếm và tra cứu hồ sơ.
- Tăng cường bảo mật và xác thực dữ liệu.
- Phục vụ thống kê và quản lý lịch sử truy cập.
- Hỗ trợ phát hiện các hành vi bất thường.

- Minh họa Metadata



- Ví dụ Metadata của một CV

Trường	Giá trị mẫu
candidate_id	CAND000125
job_id	JOB2026008
upload_time	03/07/2026 14:30
expire_time	10/07/2026 23:59
nonce	A8F4D29BC731

- Ý nghĩa đối với đề tài

Trong hệ thống **Secure Recruitment Submission**, metadata giúp quản lý và bảo vệ mỗi CV một cách hiệu quả. Đặc biệt, trường **nonce** góp phần ngăn chặn tấn công phát lại (Replay Attack), còn **upload_time** và **expire_time** hỗ trợ kiểm soát thời gian hiệu lực của hồ sơ. Kết hợp với mã hóa, hàm băm và xác thực người dùng, metadata giúp nâng cao tính an toàn và độ tin cậy của hệ thống.

CHƯƠNG III.PHÂN TÍCH YÊU CẦU

1.Chức năng của hệ thống

- **Tổng quan:** Hệ thống Secure Recruitment Submission được xây dựng nhằm đảm bảo quá trình gửi, lưu trữ và truy cập CV diễn ra an toàn. Hệ thống có ba tác nhân chính gồm Ứng viên**,** Hệ thống và Nhà tuyển dụng**,** mỗi tác nhân đảm nhận những chức năng riêng.

a) Chức năng của Ứng viên

Ứng viên là người tạo và gửi hồ sơ ứng tuyển.

- Các chức năng

- Đăng ký và đăng nhập tài khoản.
- Chọn vị trí tuyển dụng.
- Upload (tải lên) CV.
- Theo dõi trạng thái hồ sơ.
- Cập nhật hoặc thay thế CV khi cần.
- Nhận thông báo khi CV được tiếp nhận.

b) Chức năng của Hệ thống

Sau khi nhận CV, hệ thống sẽ tự động xử lý theo quy trình bảo mật.

1. Kiểm tra (Validation)

- Kiểm tra định dạng tệp (PDF, DOCX...).
- Kiểm tra kích thước tệp.
- Kiểm tra thông tin đăng nhập.
- Kiểm tra quyền của người dùng.

2. Mã hóa (Encryption)

- Mã hóa nội dung CV.

- Tạo khóa hoặc sử dụng khóa đã cấp.
- Đảm bảo dữ liệu không thể đọc nếu không có quyền.

3. Tạo Hash

- Sinh giá trị SHA-256 cho tệp CV.
- Lưu Hash để kiểm tra tính toàn vẹn.

4. Lưu trữ (Storage)

- Lưu CV đã mã hóa.
- Lưu Metadata (candidate_id, job_id, upload_time...).
- Lưu Hash và nhật ký hoạt động.

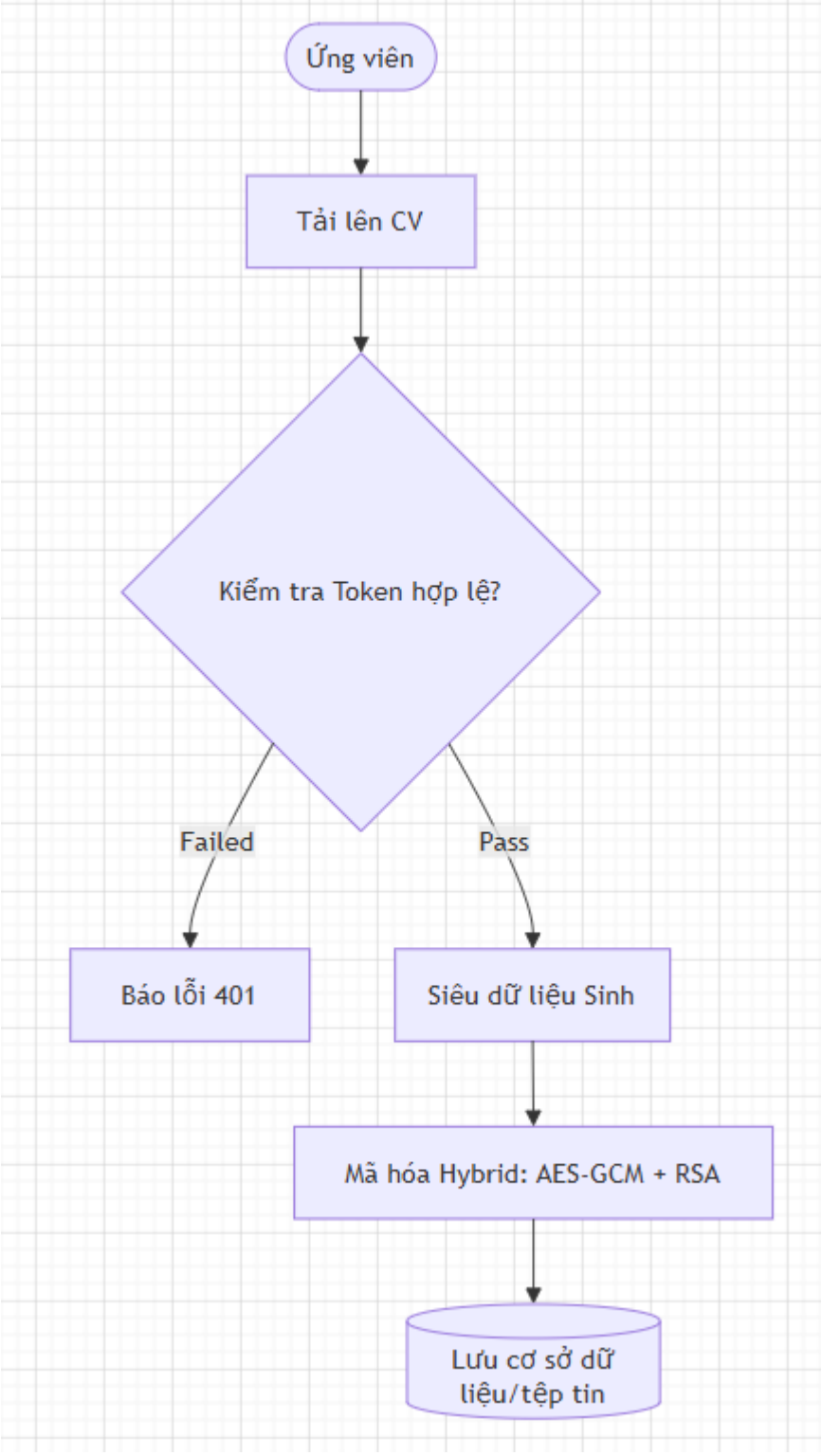
c) Chức năng của Nhà tuyển dụng

- Nhà tuyển dụng là người được cấp quyền truy cập vào hồ sơ ứng viên.

- **Các chức năng:**

- Đăng nhập hệ thống.
- Tìm kiếm hồ sơ ứng viên.
- Download CV đã mã hóa.
- Kiểm tra Hash trước khi mở tệp.
- Giải mã CV.
- Xem và đánh giá hồ sơ ứng viên.

Quy trình hoạt động Upload CV



- Lợi ích của quy trình

- Bảo vệ thông tin cá nhân của ứng viên.
- Đảm bảo dữ liệu không bị chỉnh sửa.
- Chỉ người có quyền mới được xem CV.
- Quản lý hồ sơ khoa học và dễ tra cứu.
- Nâng cao tính bảo mật và độ tin cậy của hệ thống.

2.Use Case của hệ thống

- Mục đích của Use Case

Use Case mô tả các tác nhân (Actors) tương tác với hệ thống và các chức năng mà mỗi tác nhân được phép thực hiện. Qua đó giúp xác định rõ yêu cầu chức năng của hệ thống tuyển dụng an toàn.

a) Các tác nhân (Actors)

Candidate (Ứng viên)

Là người sử dụng hệ thống để nộp hồ sơ ứng tuyển.

Chức năng

- Đăng ký và đăng nhập.
- Upload CV.
- Theo dõi trạng thái hồ sơ.
- Cập nhật hoặc thay đổi CV.
- Xem thông báo từ hệ thống.

Recruiter (Nhà tuyển dụng)

Là người có quyền truy cập và xem hồ sơ ứng viên.

Chức năng

- Đăng nhập hệ thống.
- Tìm kiếm hồ sơ ứng viên.

- Download CV.
- Kiểm tra tính toàn vẹn của dữ liệu.
- Giải mã và xem CV.

System (Hệ thống)

Hệ thống tự động xử lý các yêu cầu của người dùng.

Chức năng

- Verify (Xác thực) người dùng.
- Kiểm tra IP truy cập.
- Mã hóa dữ liệu.
- Tạo Hash SHA-256.
- Lưu Metadata.
- Ghi Log hoạt động.
- Kiểm tra quyền truy cập.

b) Các chức năng chính

Upload

- Ứng viên tải CV lên hệ thống.
- Kiểm tra định dạng và kích thước tệp.
- Chuyển dữ liệu sang bước xử lý.

Verify

- Xác thực tài khoản.
- Kiểm tra Token và IP.
- Kiểm tra quyền truy cập.

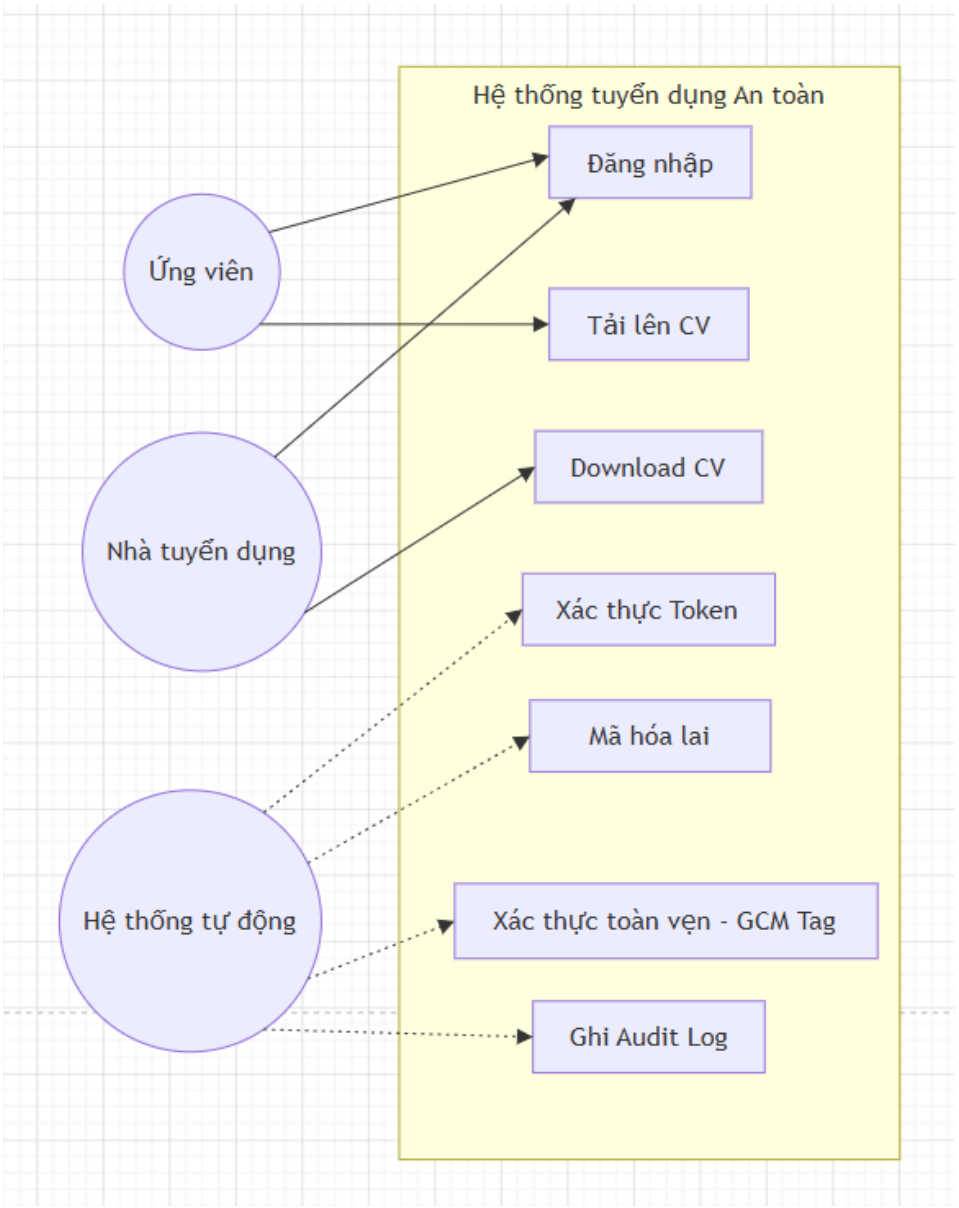
Download

- Nhà tuyển dụng tải CV đã mã hóa.
- Kiểm tra Hash trước khi mở.
- Giải mã để xem nội dung.

Log

- Ghi lại thời gian đăng nhập.
- Ghi nhận Upload và Download.
- Lưu địa chỉ IP.
- Hỗ trợ kiểm tra và xử lý sự cố.

Sơ đồ Use Case

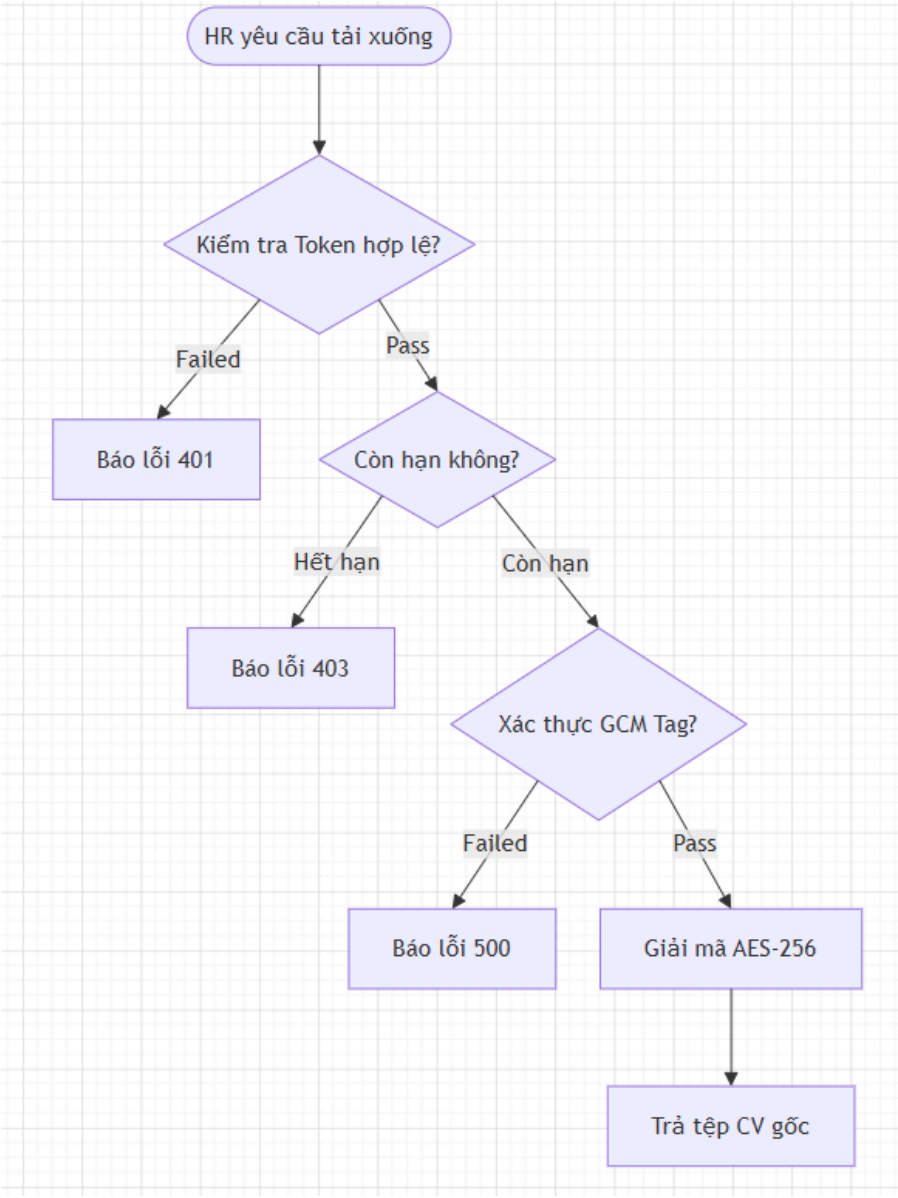


3.Luồng xử lý Upload CV

- Mục đích

- Luồng Upload mô tả toàn bộ quá trình từ khi ứng viên tải CV lên cho đến khi dữ liệu được lưu trữ an toàn trong hệ thống. Mỗi bước đều góp phần đảm bảo tính bảo mật, toàn vẹn và xác thực của dữ liệu.

- Quy trình xử lý Download CV



a) Chi tiết từng bước

1. Upload CV:

- Ứng viên điền form và chọn tệp CV. Hệ thống tiếp nhận, kiểm tra dữ liệu đầu vào.

2. Sinh Metadata:

- Hệ thống tạo danh tính ẩn danh candidate_id bằng UUID dựa trên email, gán job_id, ghi upload_time, thiết lập thời gian hết hạn expire_time (7 ngày), và sinh nonce để chống Replay Attack.

3. Sinh khóa phiên (Session Key):

- Hệ thống tự động sinh một khóa AES-256 ngẫu nhiên và một iv ngẫu nhiên cho phiên làm việc hiện tại.

4. Mã hóa CV và Metadata (AES-GCM):

- Dùng khóa AES vừa sinh để mã hóa file CV và đoạn chuỗi JSON Metadata. Trong quá trình mã hóa, chế độ GCM sẽ tự động tính toán ra thẻ xác thực Authentication Tag để chống sửa đổi (Tampering).

5. Bảo vệ khóa phiên (RSA OAEP):

- Khóa AES không lưu ở dạng bản rõ. Hệ thống dùng Public Key (RSA) mã hóa khóa AES này lại.

6. Lưu trữ an toàn:

- Gộp Ciphertext (CV + Meta), Tag xác thực và Khóa phiên đã mã hóa vào cùng một file .json_enc và lưu xuống máy chủ. Ghi Audit Log thành công.

- **Kết quả**

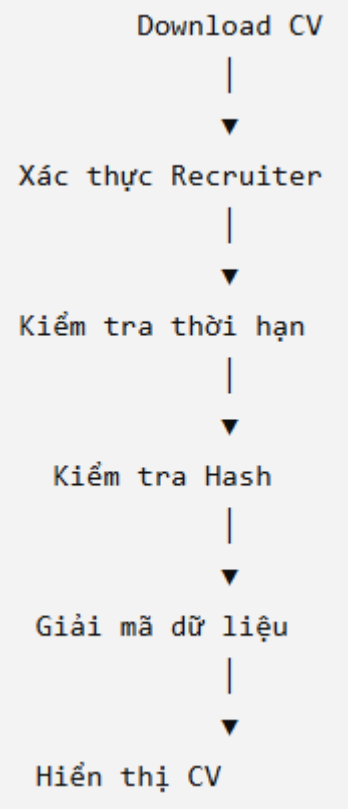
- CV được lưu an toàn.
- Thông tin ứng viên được bảo vệ.
- Có thể kiểm tra tính toàn vẹn khi tải xuống.
- Ngăn chặn truy cập trái phép và tấn công Replay.

4.Luồng xử lý Download CV

- Mục đích

Luồng Download mô tả quá trình nhà tuyển dụng truy cập và xem CV của ứng viên. Hệ thống sẽ kiểm tra quyền truy cập và tính toàn vẹn của dữ liệu trước khi giải mã và hiển thị.

- Quy trình xử lý



a) Chi tiết từng bước

1. Yêu cầu tải CV:

- Nhà tuyển dụng truy cập link tải CV, bắt buộc đính kèm ?token=... trên URL.

2. Xác thực Token (Authentication):

- Hệ thống kiểm tra Token gửi lên có khớp với danh sách VALID_TOKENS hay không. Nếu sai, báo lỗi HTTP 401 Unauthorized và ghi Log truy cập trái phép.

3. Giải mã Metadata & Kiểm tra thời hạn:

- Dùng Private Key (RSA) để khôi phục khóa AES, sau đó dùng AES giải mã đoạn Metadata. So sánh thời gian hiện tại với expire_time. Nếu đã quá hạn 7 ngày, từ chối truy cập (HTTP 403).

4. Kiểm tra toàn vẹn (Tampering Check):

- Quá trình giải mã file CV bằng thuật toán AES-GCM sẽ đồng thời tính toán lại thẻ Authentication Tag. Nếu Tag lệch (do file bị sửa đổi trái phép dù chỉ 1 byte), lập tức dừng giải mã, báo lỗi HTTP 500 và ghi cảnh báo.

5. Trả file an toàn:

- Dữ liệu hợp lệ được giải mã hoàn toàn. Hệ thống xử lý chuẩn hóa tên file (Unicode Handling) và trả tệp PDF/DOCX gốc về cho nhà tuyển dụng thông qua HTTP Response.

- **Kết quả**

- Chỉ nhà tuyển dụng được cấp quyền mới xem được CV.
- Dữ liệu được xác minh là chưa bị chỉnh sửa.
- Nội dung CV được giải mã an toàn.
- Hệ thống ghi lại lịch sử truy cập để phục vụ kiểm tra.

CHƯƠNG IV.GIẢI PHÁP BẢO MẬT

1.Xác thực nhiều lớp (Multi-Factor Authentication)

- Khái niệm

Xác thực nhiều lớp (Multi-Factor Authentication - MFA) là phương pháp kết hợp nhiều yếu tố xác thực để đảm bảo chỉ người dùng hợp lệ mới được phép truy cập hệ thống. So với việc chỉ sử dụng mật khẩu, MFA giúp giảm đáng kể nguy cơ tài khoản bị chiếm quyền.

Các lớp xác thực của hệ thống

1. Username (Tên đăng nhập)

- Định danh duy nhất của người dùng.
- Dùng để phân biệt ứng viên và nhà tuyển dụng.
- Là bước đầu tiên trong quá trình đăng nhập.

2. Password (Mật khẩu)

- Chứng minh người dùng sở hữu tài khoản.
- Được lưu dưới dạng Hash để tăng tính bảo mật.
- Khuyến khích sử dụng mật khẩu mạnh gồm chữ hoa, chữ thường, số và ký tự đặc biệt.

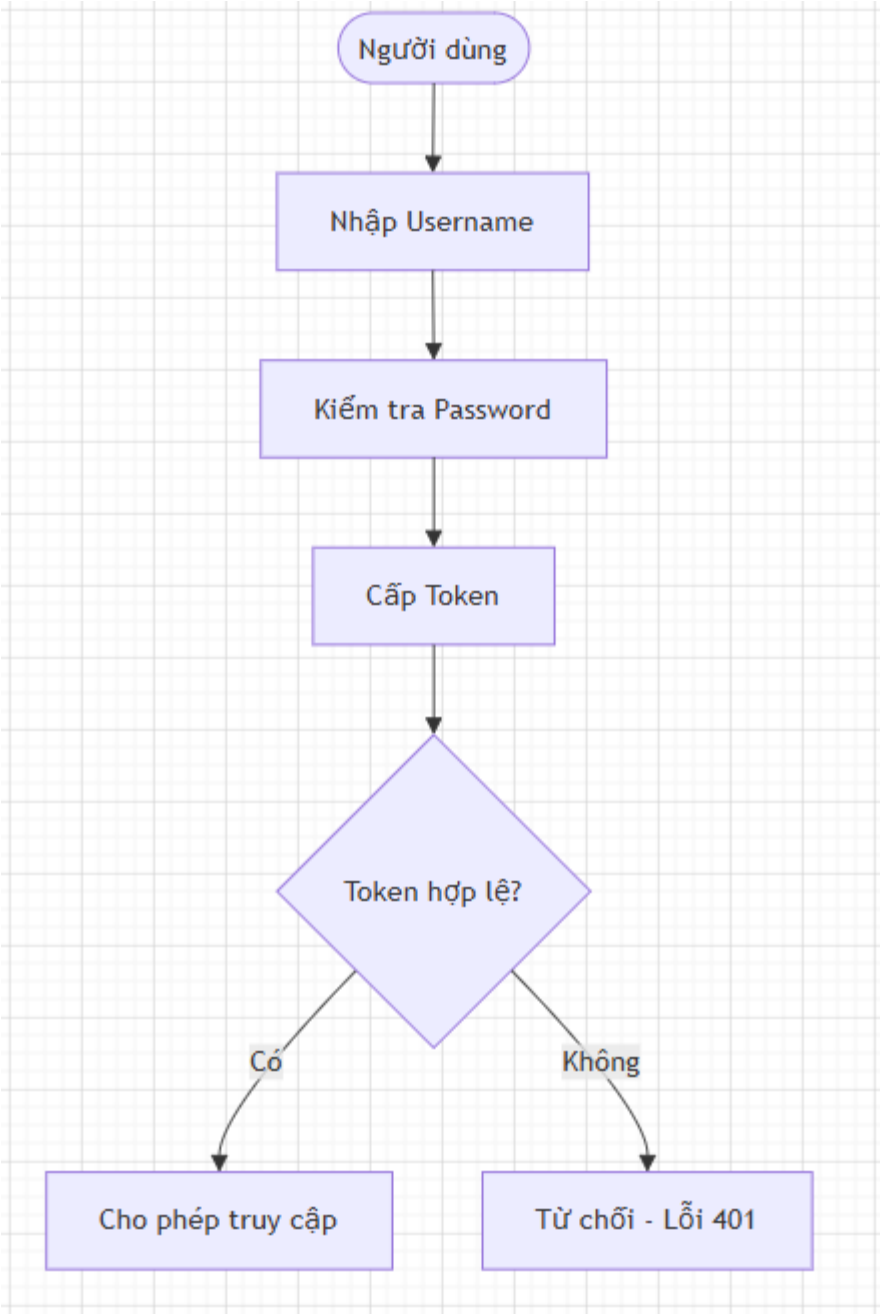
3. Token

- Được cấp sau khi đăng nhập thành công.
- Dùng để xác thực các yêu cầu gửi đến hệ thống.
- Có thời gian hết hạn nhằm giảm nguy cơ bị lợi dụng.

4. Kiểm tra địa chỉ IP

- Xác định nguồn truy cập của người dùng.
- Phát hiện IP bất thường hoặc có dấu hiệu tấn công.
- Ghi nhận IP vào nhật ký để hỗ trợ kiểm tra khi cần.

- Quy trình xác thực



- Lợi ích

- Tăng cường bảo mật tài khoản.
- Hạn chế giả mạo người dùng.
- Giảm nguy cơ truy cập trái phép.
- Hỗ trợ ghi nhật ký và truy vết hoạt động.
- Bảo vệ hệ thống trước nhiều hình thức tấn công.

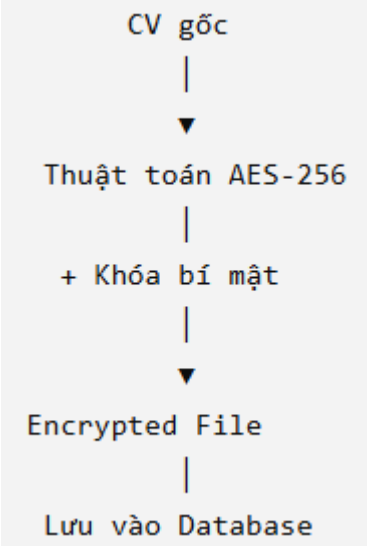
- Ứng dụng trong đề tài

- Ứng viên và nhà tuyển dụng đều phải đăng nhập.
- Hệ thống kiểm tra Username, Password, Token và địa chỉ IP.
- Chỉ khi tất cả các bước đều hợp lệ, người dùng mới được phép Upload hoặc Download CV.

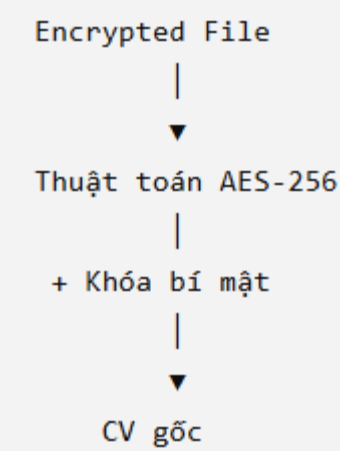
2. Cơ chế Mã hóa lai (Hybrid Encryption) bằng AES-GCM và RSA

- **Khái niệm: AES-256 (Advanced Encryption Standard 256-bit)** là thuật toán mã hóa đối xứng được sử dụng rộng rãi trong các hệ thống bảo mật hiện đại. Thuật toán sử dụng khóa có độ dài **256 bit**, mang lại mức độ bảo mật rất cao và tốc độ xử lý nhanh.

- Quy trình mã hóa



- Quy trình giải mã

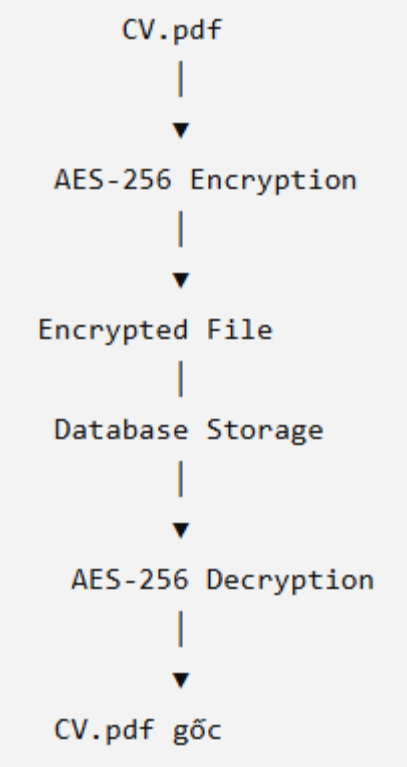


- Hệ thống không chỉ sử dụng mã hóa đối xứng đơn thuần mà áp dụng kiến trúc mã hóa lai nhằm tối ưu hóa bảo mật và tốc độ:

- **Mã hóa dữ liệu (AES-256-GCM):** Tệp CV (PDF/DOCX) và Metadata của ứng viên được mã hóa bằng thuật toán AES. Khóa AES (Session Key) được sinh ngẫu nhiên cho mỗi lần upload. Chế độ GCM (Galois/Counter Mode) được lựa chọn vì đây là thuật toán mã hóa có xác thực (AEAD - Authenticated Encryption with Associated Data).

- **Bảo vệ khóa (RSA-2048 OAEP):** Khóa AES không được lưu dưới dạng bản rõ. Máy chủ sử dụng Public Key (RSA) để mã hóa khóa AES này. Chỉ Nhà tuyển dụng nắm giữ Private Key hợp lệ (được bảo vệ bằng mật khẩu) mới có thể giải mã lấy lại khóa AES, từ đó khôi phục nội dung CV. Quy trình này giúp hệ thống đạt chuẩn Zero-Trust.

- Minh họa

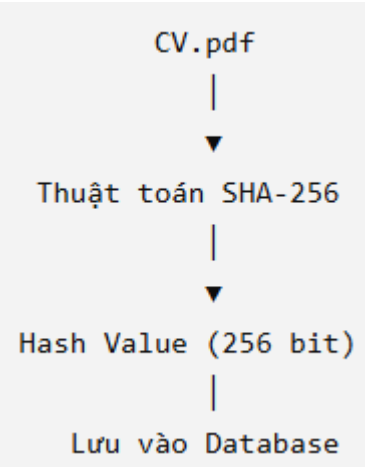


3. Kiểm tra tính toàn vẹn bằng Authentication Tag (Chống Tampering)

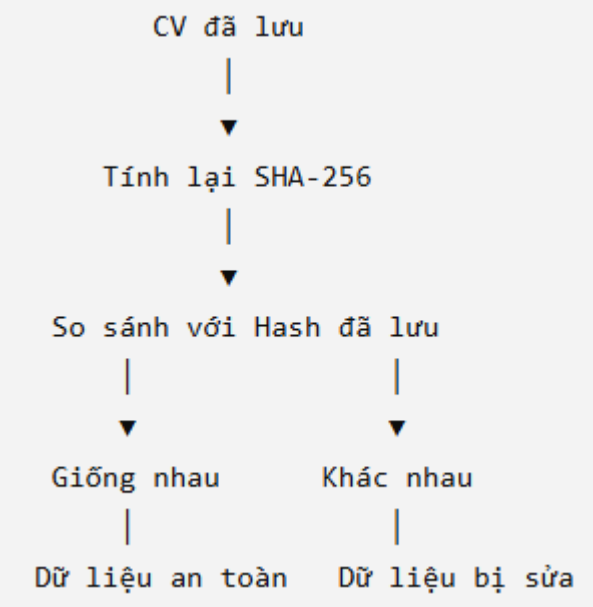
- Khái niệm

Hash là quá trình sử dụng một **hàm băm (Hash Function)** để chuyển đổi dữ liệu thành một chuỗi ký tự có độ dài cố định gọi là **Hash Value**. Trong hệ thống tuyển dụng, Hash không dùng để mã hóa mà dùng để kiểm tra xem CV có bị thay đổi hay không.

- Quy trình tạo Hash



- Quy trình kiểm tra Hash



- Thay vì sử dụng hàm băm SHA-256 rời rạc, hệ thống nâng cấp sử dụng chế độ AES-GCM. Khi mã hóa, thuật toán tự động sinh ra một Authentication Tag đính kèm cùng dữ liệu Ciphertext.

- **Phát hiện Tampering:** Nếu tin tặc xâm nhập vào máy chủ lưu trữ (Thư mục uploaded_files) và cố tình chỉnh sửa dù chỉ 1 byte của file JSON mã hóa, Tag sẽ bị sai lệch.

- **Phản hồi của hệ thống:** Khi Nhà tuyển dụng tiến hành giải mã, hàm AES-GCM sẽ tính toán lại Tag. Do Tag không khớp, hệ thống ngay lập tức chặn quá trình giải mã, ghi nhận cảnh báo đỏ vào file Log và trả về lỗi HTTP 500: Nội dung CV đã bị sửa đổi trái phép.

4.Metadata trong hệ thống

- Khái niệm

Metadata là **dữ liệu mô tả về dữ liệu**. Trong hệ thống gửi CV trực tuyến, Metadata không chứa nội dung của CV mà lưu các thông tin quản lý giúp hệ thống xác định, theo dõi và bảo vệ từng hồ sơ.

a) Các trường Metadata

- Candidate ID

- Mã định danh duy nhất của ứng viên.
- Liên kết CV với tài khoản người dùng.
- Hỗ trợ tìm kiếm và quản lý hồ sơ.

- Job ID

- Mã của vị trí tuyển dụng.
- Xác định CV được gửi cho công việc nào.
- Hỗ trợ quản lý nhiều hồ sơ ứng tuyển.

- Nonce

- Giá trị ngẫu nhiên chỉ sử dụng một lần.
- Chống tấn công **Replay Attack**.
- Đảm bảo mỗi yêu cầu Upload là duy nhất.

- Upload Time

- Thời gian ứng viên tải CV lên.
- Phục vụ thống kê và theo dõi lịch sử.

- Expire Time

- Thời điểm hồ sơ hoặc liên kết hết hiệu lực.
- Hạn chế truy cập sau khoảng thời gian quy định.
- Tăng cường mức độ bảo mật.

b) Ví dụ Metadata

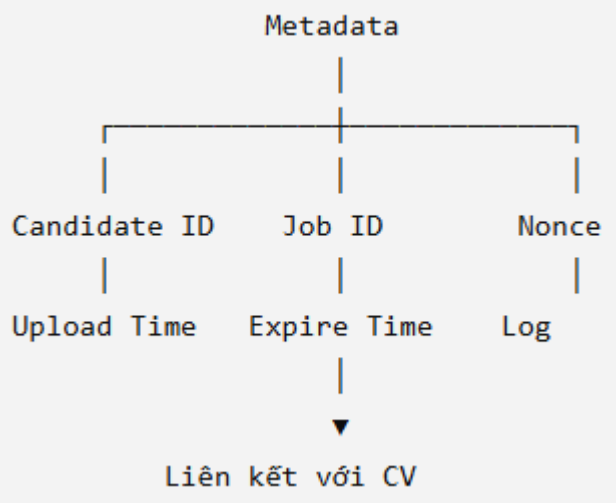
Trường	Giá trị mẫu
Candidate ID	CAND000125

Job ID	JOB2026008
Nonce	A8F4D29BC731
Upload Time	03/07/2026 14:30
Expire Time	10/07/2026 23:59

c) Vai trò của Metadata

- Quản lý từng hồ sơ ứng viên.
- Hỗ trợ tìm kiếm và tra cứu nhanh.
- Tăng cường bảo mật hệ thống.
- Chống Replay Attack bằng Nonce.
- Hỗ trợ ghi nhật ký và kiểm tra lịch sử truy cập.

Mô hình Metadata



- Ứng dụng trong đề tài

Metadata được tạo ngay sau khi ứng viên tải CV lên và được lưu cùng với tệp CV đã mã hóa. Khi nhà tuyển dụng truy cập hồ sơ, hệ thống sẽ sử dụng Metadata để xác định đúng ứng viên, đúng vị trí tuyển dụng, kiểm tra thời hạn hiệu lực và hỗ trợ xác minh tính hợp lệ của yêu cầu truy cập.

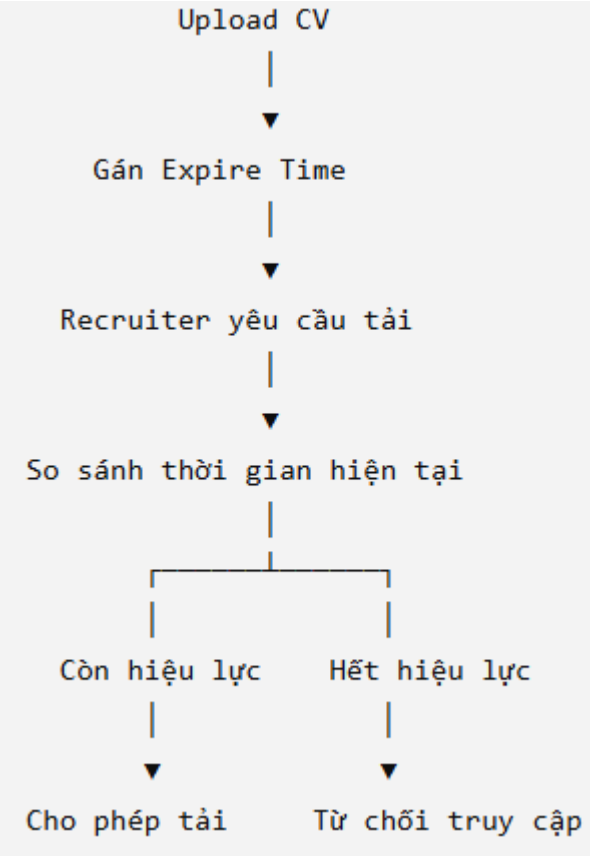
5.Cơ chế hết hạn (Expire Time)

- **Khái niệm:** Cơ chế **Expire Time** là giải pháp quy định thời gian hiệu lực của một hồ sơ CV hoặc liên kết tải xuống. Sau khi hết thời gian quy định, hệ thống sẽ tự động từ chối truy cập nhằm giảm nguy cơ rò rỉ dữ liệu và tăng cường bảo mật.

- **Mục đích của Expire Time**

- Giới hạn thời gian truy cập vào CV.
- Ngăn chặn việc sử dụng các liên kết cũ.
- Giảm nguy cơ truy cập trái phép.
- Quản lý vòng đời của hồ sơ ứng tuyển.
- Đảm bảo chỉ những hồ sơ còn hiệu lực mới được phép truy cập.

Quy trình kiểm tra



a) Cách hoạt động

- Khi Upload

- Hệ thống lưu thời gian tải lên (**Upload Time**).
- Thiết lập thời gian hết hạn (**Expire Time**).
- Lưu thông tin vào Metadata.

- Khi Download

- Kiểm tra thời gian hiện tại.
- So sánh với Expire Time.
- Nếu chưa hết hạn → tiếp tục kiểm tra Hash và giải mã.
- Nếu đã hết hạn → dừng xử lý và thông báo từ chối.

- Lợi ích

- Hạn chế truy cập sau thời gian quy định.
- Giảm nguy cơ lộ dữ liệu nếu liên kết bị chia sẻ.
- Hỗ trợ doanh nghiệp quản lý hồ sơ theo từng đợt tuyển dụng.
- Tự động hóa quá trình kiểm soát quyền truy cập.

6. Phân tích mã nguồn

- Toàn bộ hệ thống được viết bằng ngôn ngữ Python sử dụng framework Flask và thư viện mã hóa chuẩn cryptography.

- Cấu trúc thư mục dự án:

+ app.py: File máy chủ chính, định nghĩa API định tuyến (/upload_cv, /download_cv) và thực thi thuật toán mã hóa lai Hybrid Encryption.

+ generate_keys.py: Script khởi tạo cặp khóa bảo mật RSA-2048 ban đầu, trong đó private_key được yêu cầu bảo mật bằng mật khẩu mạnh.

+ templates/index.html: Chứa giao diện Frontend tương tác với người dùng.

+**uploaded_files/:** Thư mục lưu trữ các file .json_enc đã được mã hóa an toàn.

+ **audit_access.log:** File ghi lại nhật ký truy cập, cảnh báo bảo mật.

- Các hàm quan trọng trong app.py:

+ **encrypt_payload_hybrid(data_bytes):** Chịu trách nhiệm mã hóa ngẫu nhiên dữ liệu bằng AES-GCM, sinh Tag xác thực và dùng khóa Public RSA để bọc khóa AES lại.

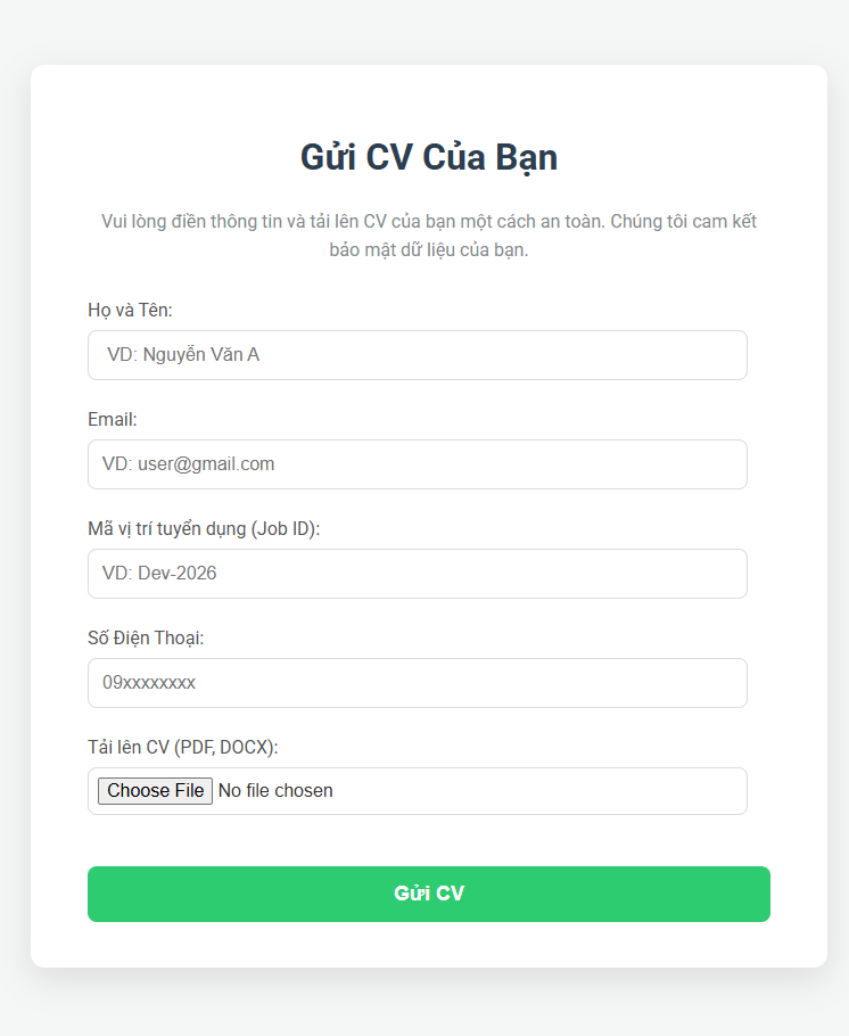
+ **decrypt_payload_hybrid(...):** Mở khóa AES bằng Private RSA, kiểm tra tính toàn vẹn (Tag) và khôi phục bản rõ.

+ **upload_cv():** Xử lý request, sinh Metadata, mã hóa file và lưu xuống đĩa.

+ **download_cv(file_id):** Xác thực Token từ URL, đối chiếu thời gian Expire Time, kiểm tra Tampering và trả file về trình duyệt có xử lý chuẩn Unicode.

CHƯƠNG V.DEMO HỆ THỐNG

1.Giao diện Upload CV



Giao diện Upload CV

- Mục đích

Đây là giao diện để ứng viên gửi CV lên hệ thống. Giao diện được thiết kế đơn giản, dễ sử dụng và tích hợp các chức năng kiểm tra bảo mật trước khi lưu dữ liệu.

2. Các thành phần trên giao diện

a) Thông tin ứng viên

- Họ và tên
- Email
- Vị trí ứng tuyển (Job ID)
- Số điện thoại

b) Chọn tệp CV

- Hỗ trợ định dạng **PDF** và **DOCX**
- Kiểm tra kích thước tệp
- Hiển thị tên tệp sau khi chọn

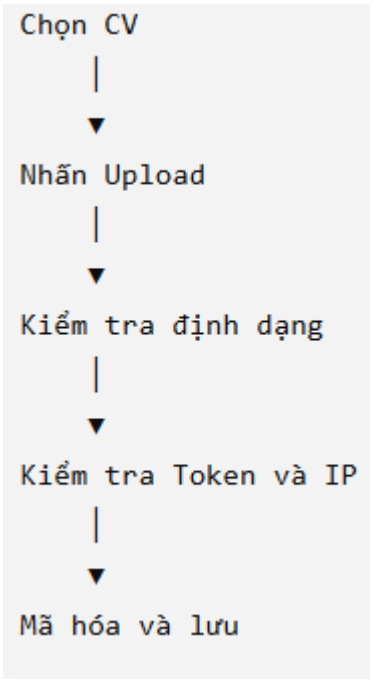
c) Nút Upload

- Gửi CV lên máy chủ
- Bắt đầu quy trình kiểm tra và mã hóa

d) Thông báo

- Upload thành công
- Upload thất bại
- Báo lỗi nếu tệp không hợp lệ

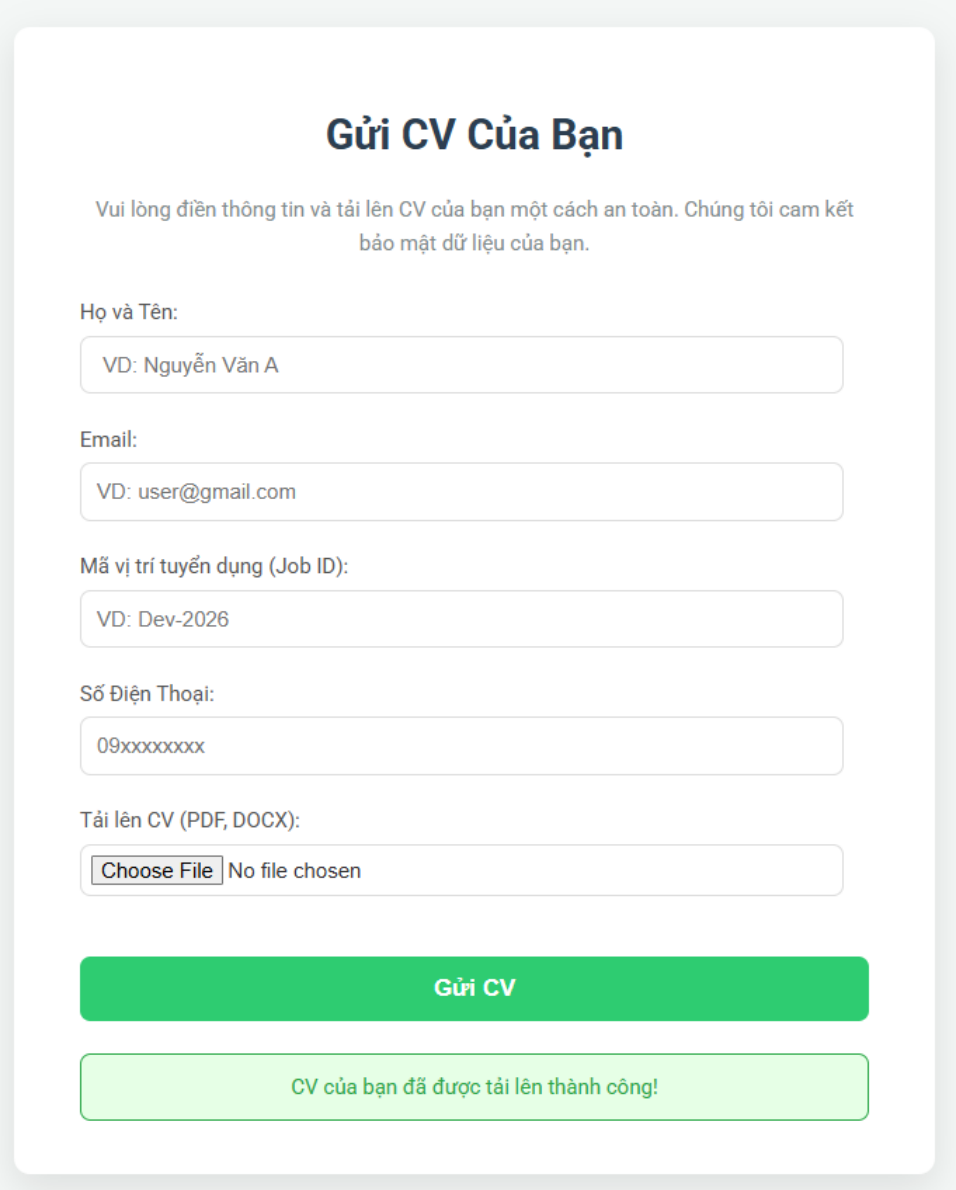
- Quy trình xử lý



- Kết quả

- CV được tải lên thành công.
- Dữ liệu được mã hóa.
- Sinh Hash và Metadata.
- Lưu vào cơ sở dữ liệu.

3.Kết quả Upload thành công



Giao diện hiện thông báo khi Upload CV thành công

a) Thông tin hiển thị

- Token

- Token xác thực được cấp sau khi đăng nhập.
- Dùng để xác minh các yêu cầu tiếp theo.
- Có thời gian hết hạn.

- Metadata hiển thị các thông tin:

- **Candidate ID (Mã định danh ứng viên):** Chuỗi ký tự duy nhất (UUID) sinh tự động cho mỗi hồ sơ. Giúp định danh chính xác dữ liệu của từng ứng viên trong cơ sở dữ liệu mà không cần làm lộ các thông tin cá nhân trực tiếp (Ẩn danh hóa dữ liệu).
- **Job ID (Mã vị trí tuyển dụng):** Mã trích xuất từ biểu mẫu do người dùng nhập vào, dùng để liên kết hồ sơ ứng viên với luồng quy trình tuyển dụng và vị trí công việc tương ứng.
- **Upload Time (Thời gian tải lên):** Mốc thời gian (ngày, giờ, giây) máy chủ tiếp nhận tệp tin. Đây là căn cứ kỹ thuật phục vụ cho công tác kiểm toán hệ thống (Audit Trail) và xác định tính hợp lệ về thời gian nộp hồ sơ.
- **Expire Time (Thời gian hết hạn):** Giới hạn hiệu lực lưu trữ của Token và liên kết tải xuống (thường cấu hình 30 ngày). Sau thời hạn này, hệ thống tự động vô hiệu hóa truy cập nhằm tuân thủ nguyên tắc hạn chế lưu trữ dữ liệu (Storage Limitation) của an toàn thông tin.
- **Nonce (Số ngẫu nhiên dùng một lần):** Chuỗi giá trị ngẫu nhiên đóng vai trò là Vector khởi tạo (Initialization Vector - IV) cho thuật toán AES-256. Thành phần này đảm bảo nếu hai ứng viên tải lên hai tệp CV giống hệt nhau, kết quả bản mã (Ciphertext) lưu trên ổ đĩa vẫn hoàn toàn khác biệt, ngăn chặn hiệu quả các cuộc tấn công lặp lại (Replay Attacks) hoặc tấn công phân tích tần suất.

- Hash

- Giá trị SHA-256 của tệp CV.
- Dùng để kiểm tra tính toàn vẹn.

- Trạng thái mã hóa

- CV đã được mã hóa bằng AES-256.
- Sẵn sàng lưu trữ an toàn.

- **Minh họa**

```
Upload thành công

✓ Token hợp lệ

✓ Metadata đã tạo

✓ Hash SHA-256

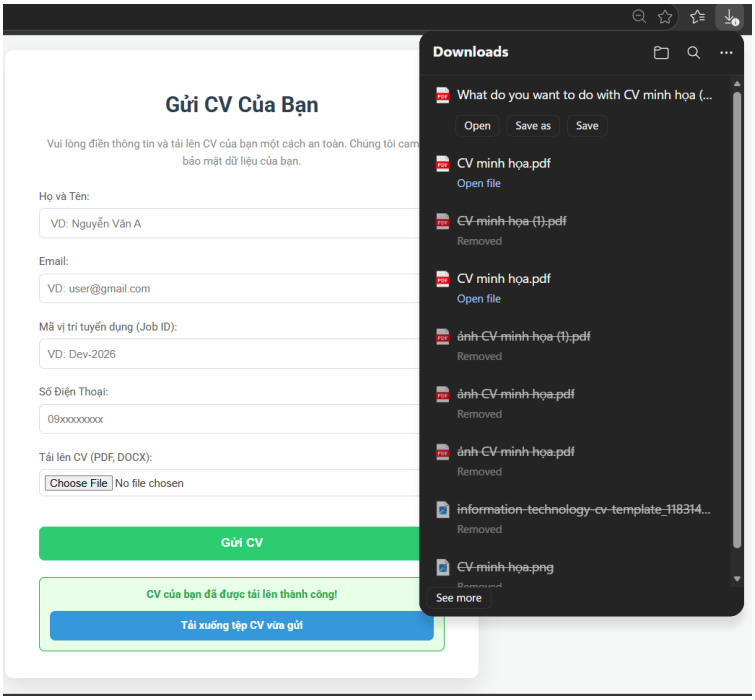
✓ AES-256 Encryption

✓ Lưu Database
```

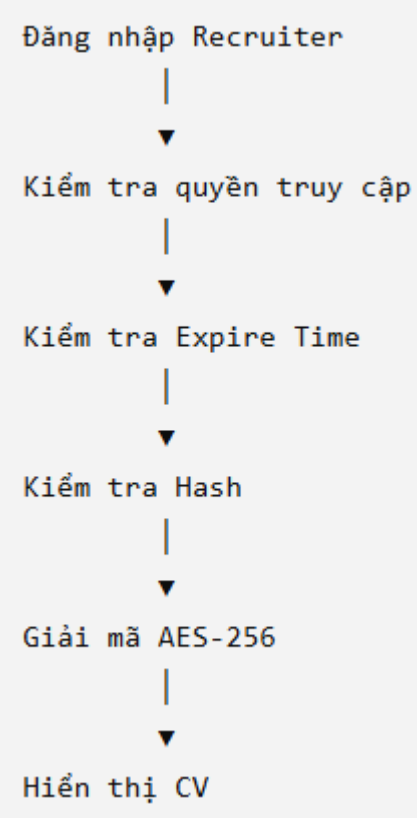
- Ý nghĩa

- Xác nhận quá trình Upload hoàn tất.
- Người dùng biết CV đã được bảo vệ.
- Hệ thống đã lưu đầy đủ thông tin cần thiết.

4.Giao diện Download



Quy trình Download



a) Các bước xử lý

Bước 1: Kiểm tra quyền

- Xác thực tài khoản nhà tuyển dụng.
- Kiểm tra Token.
- Kiểm tra quyền truy cập.

Bước 2: Kiểm tra thời hạn

- So sánh với **Expire Time**.
- Nếu hết hạn → từ chối truy cập.

Bước 3: Kiểm tra Hash

- Tính lại SHA-256.
- So sánh với giá trị Hash đã lưu.

Bước 4: Giải mã

- Sử dụng khóa AES-256.
- Khôi phục CV về dạng gốc.

Bước 5: Hiển thị

- Hiển thị nội dung CV.
- Ghi nhật ký truy cập vào hệ thống.

- Kết quả

- Chỉ người có quyền mới xem được CV.
- CV không bị chỉnh sửa.
- Dữ liệu được giải mã an toàn.
- Hệ thống ghi nhận lịch sử truy cập.

CHƯƠNG VI. KIỂM THỬ HỆ THỐNG

1.Test Case

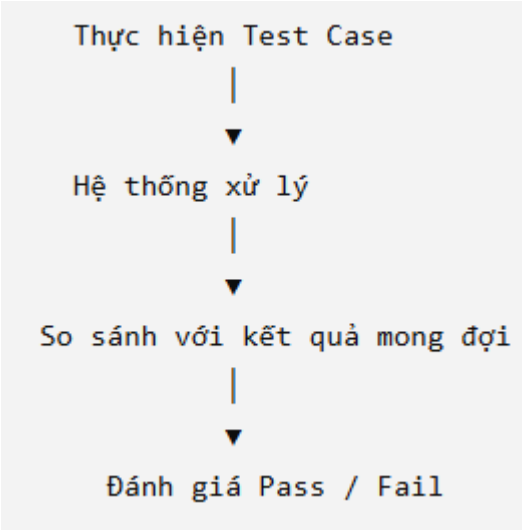
- **Mục đích kiểm thử:** Kiểm thử nhằm đánh giá các chức năng bảo mật của hệ thống, đảm bảo quá trình Upload, Download và truy cập CV hoạt động đúng theo yêu cầu, đồng thời phát hiện và ngăn chặn các hành vi truy cập trái phép.

- **Bảng kế thừa và nâng cấp**

Thành phần	**Bài khóa trước có gì?**	**Nhóm kế thừa gì?**	**Nhóm nâng cấp gì?**	**Minh chứng**
Giao diện	Giao diện cơ bản tải CV	Giữ nguyên cấu trúc Form cơ bản.	Làm mới giao diện, tự động sinh khung kết quả và nút bấm Download trực tiếp.	Ảnh giao diện / Video Demo
Xác thực	Dùng IP tĩnh (Dễ bị giả mạo).	Không kế thừa (Hủy bỏ IP).	Nâng cấp lên xác thực bằng Token truyền qua URL (VALID_TOKENS).	Test Case lỗi 401 / Mã nguồn API
Thuật toán	Chỉ có mã hóa AES đơn thuần.	Không kế thừa.	Hybrid Cryptography: AES-256-GCM kết hợp bảo vệ khóa bằng RSA-2048 OAEP.	Code hàm encrypt_payload_hybrid
Kiểm tra toàn vẹn	Không có chức năng này.	Không kế thừa.	Tamper-Evident: Dùng Authentication Tag của chế độ GCM phát hiện sửa file.	Test Case lỗi 500

Quản lý khóa	Hard-code mật khẩu bảo vệ khóa.	Không kế thừa.	Lấy mật khẩu RSA an toàn từ biến môi trường (os.environ.get).	Mô tả trong báo cáo / Code
Thời hạn	Lưu vĩnh viễn trên máy chủ.	Không kế thừa.	Expire Time: Hạn sử dụng 7 ngày lưu trong Metadata.	Test Case lỗi 403 / Log
Logging	In ra màn hình console tạm thời.	Không kế thừa.	Ghi Audit Log vào file vật lý (audit_access.log), ẩn danh email bằng UUID.	File audit_access.log
Xử lý lỗi File	Lỗi HTTP Header khi tải file tiếng Việt.	Không kế thừa.	Dùng urllib.parse chuẩn hóa tên file tiếng Việt có dấu.	Ảnh tải file thành công

- Quy trình kiểm thử



2.Kết quả kiểm thử

- **Tổng quan:** Sau khi thực hiện các Test Case, hệ thống hoạt động đúng theo thiết kế và đáp ứng các yêu cầu về bảo mật cũng như quản lý dữ liệu.

a) Kết quả đạt được

- Upload thành công

- CV hợp lệ được tải lên hệ thống.
- Dữ liệu được mã hóa bằng AES-256.
- Metadata và Hash được tạo đầy đủ.

- Token hoạt động chính xác

- Chỉ Token hợp lệ mới được chấp nhận.
- Token hết hạn hoặc không hợp lệ đều bị từ chối.
- Đảm bảo phiên đăng nhập an toàn.

- Xác thực tính toàn vẹn bằng GCM Tag

- Hệ thống thực hiện kiểm tra thẻ xác thực (Authentication Tag) trong quá trình giải mã. Nếu tệp CV bị chỉnh sửa bất hợp pháp (Tampering), hàm giải mã sẽ không khớp Tag và từ chối cung cấp dữ liệu. Điều này đảm bảo tính toàn vẹn của tệp tin một cách chặt chẽ và tự động- Log được ghi nhận
- Ghi lại tài khoản truy cập.
- Lưu địa chỉ IP.
- Ghi thời gian thực hiện thao tác.
- Lưu kết quả xử lý (thành công hoặc thất bại).

- Đánh giá

- Đáp ứng các yêu cầu bảo mật của mô hình CIA.
- Bảo vệ tốt thông tin ứng viên.
- Phát hiện hiệu quả các hành vi truy cập trái phép và sửa đổi dữ liệu.
- Hệ thống hoạt động ổn định và sẵn sàng mở rộng trong tương lai

CHƯƠNG VII. ĐÁNH GIÁ MỨC ĐỘ KẾ THỪA VÀ NÂNG CẤP

Tiêu chí Bảo mật	Hệ thống Cũ (Bản gốc kế thừa)	Hệ thống nâng cấp
Cơ chế Xác thực	Dùng IP Whitelist tĩnh. Rất dễ bị tấn công giả mạo (IP Spoofing).	**Nâng cấp:** Hủy bỏ IP. Sử dụng Mã xác thực (Token-based) truyền qua tham số URL.
Thuật toán Mã hóa	Mã hóa đơn giản, dễ bị lộ khóa.	**Nâng cấp:** Hybrid Cryptography (AES-256-GCM kết hợp bảo vệ khóa bằng RSA-2048 OAEP).
Kiểm tra Toàn vẹn	Không có. Hacker sửa file hệ thống không phát hiện được.	**Thêm mới:** Tích hợp Tag xác thực của GCM. Báo lỗi 500 ngay lập tức nếu file bị sửa đổi (Chống Tampering).
Quản lý vòng đời	CV lưu trữ vĩnh viễn, rủi ro rò rỉ theo thời gian.	**Thêm mới:** Cấu hình Expire_time (7 ngày) lưu trong Metadata. Tự động đóng quyền truy cập (Lỗi 403).
Truy vết (Logging)	In thông báo cơ bản ra màn hình Console (bị mất khi tắt server).	**Thêm mới:** Ghi log hệ thống vào file cứng audit_access.log, ẩn danh Email ứng viên bằng UUID.

CHƯƠNG VIII. ĐÁNH GIÁ VÀ KẾT LUẬN

1.Ưu điểm của hệ thống

- Tổng quan

Sau quá trình thiết kế, xây dựng và kiểm thử, hệ thống **Secure Recruitment Submission** đã đáp ứng các mục tiêu về bảo mật, quản lý và lưu trữ CV của ứng viên. Các cơ chế như mã hóa, kiểm tra Hash, xác thực và ghi nhật ký giúp nâng cao độ an toàn cho dữ liệu.

a) Những ưu điểm nổi bật

1. Bảo mật cao

- Kết hợp nhiều lớp bảo mật như xác thực người dùng, Token
- Hạn chế tối đa nguy cơ truy cập trái phép.
- Bảo vệ thông tin cá nhân của ứng viên.

2. Mã hóa dữ liệu

- Sử dụng thuật toán **AES-256** để mã hóa CV.
- Dữ liệu được bảo vệ trong cả quá trình lưu trữ và truyền tải.
- Chỉ người có quyền mới có thể giải mã.

3. Kiểm tra tính toàn vẹn

- Áp dụng cơ chế **Authentication Tag** trong mã hóa AES-GCM.
- Phát hiện mọi hành vi can thiệp, sửa đổi trái phép vào dữ liệu CV đã lưu.
- Đảm bảo tính toàn vẹn của tệp tin một cách chính xác mà không cần băm rời rạc.

4. Theo dõi truy cập

- Ghi lại thông tin tài khoản, IP, thời gian và kết quả truy cập.
- Hỗ trợ kiểm tra, truy vết và điều tra khi có sự cố.
- Tăng tính minh bạch trong quản lý hệ thống.

5. Quản lý thời hạn

- Sử dụng **Expire Time** để giới hạn thời gian truy cập.
- Tự động từ chối các yêu cầu sau khi hết hiệu lực.
- Giảm nguy cơ lộ dữ liệu do sử dụng liên kết cũ.

b) Đánh giá chung

- Đáp ứng các yêu cầu bảo mật của mô hình CIA.
- Quy trình xử lý rõ ràng và an toàn.
- Dễ mở rộng và tích hợp thêm các tính năng mới.
- Phù hợp với hệ thống tuyển dụng trực tuyến hiện đại.

2.Hạn chế của hệ thống

- **Tổng quan:** Mặc dù hệ thống đáp ứng tốt các yêu cầu bảo mật cơ bản, vẫn còn một số hạn chế cần được cải thiện để đáp ứng các hệ thống quy mô lớn hoặc có yêu cầu bảo mật cao hơn.

a) Các hạn chế

1. Phụ thuộc vào máy chủ

- Hầu hết các chức năng xử lý đều thực hiện trên máy chủ.
- Khi máy chủ gặp sự cố, hệ thống có thể bị gián đoạn.
- Cần có cơ chế sao lưu và dự phòng.

2. Quản lý khóa mã hóa

- Khóa AES cần được lưu trữ an toàn.
- Nếu khóa bị lộ, dữ liệu mã hóa có nguy cơ bị giải mã.
- Cần áp dụng hệ thống quản lý khóa chuyên dụng.

3. Token cần được bảo vệ

- Token bị đánh cắp có thể bị lợi dụng nếu còn hiệu lực.
- Cần giới hạn thời gian sử dụng và thu hồi Token khi cần.
- Có thể kết hợp với xác thực đa yếu tố.

4. Hiệu năng giảm với tệp lớn

- Quá trình mã hóa và tạo Hash tiêu tốn tài nguyên.
- Thời gian xử lý tăng khi kích thước tệp lớn hoặc số lượng người dùng tăng.
- Cần tối ưu thuật toán và hạ tầng xử lý.

b) Hướng cải thiện

- Tăng khả năng mở rộng của hệ thống.
- Tối ưu tốc độ mã hóa.
- Bổ sung cơ chế sao lưu và cân bằng tải.
- Nâng cao khả năng quản lý khóa và Token.

3.Kết luận và hướng phát triển

- **Kết luận:** Đề tài **Secure Recruitment Submission** đã xây dựng thành công một giải pháp bảo mật cho quá trình gửi và quản lý CV trong tuyển dụng trực tuyến.

- Những kết quả đạt được:

- Đảm bảo **tính bí mật (Confidentiality)** bằng mã hóa **AES-256**, giúp bảo vệ thông tin cá nhân của ứng viên.
- Đảm bảo tính toàn vẹn (Integrity) bằng Authentication Tag của AES-GCM
- Đảm bảo **xác thực (Authentication)** thông qua tài khoản, Token
- Đảm bảo **phân quyền (Authorization)**, chỉ nhà tuyển dụng được cấp quyền mới có thể xem và tải CV.
- Ghi nhật ký truy cập (Access Log) giúp theo dõi, kiểm tra và truy vết khi có sự cố.
- Đáp ứng đầy đủ các yêu cầu và mục tiêu của đề tài về bảo mật dữ liệu tuyển dụng.

- **Hướng phát triển**

Để nâng cao khả năng bảo mật và mở rộng ứng dụng trong thực tế, hệ thống có thể phát triển thêm các chức năng sau:

- Tích hợp **xác thực đa yếu tố (MFA)** nhằm tăng cường bảo vệ tài khoản.
- Sử dụng **chữ ký số** để xác minh nguồn gốc và tính xác thực của CV.

- Lưu trữ khóa mã hóa bằng **Key Management System (KMS)** để quản lý khóa an toàn hơn.
- Tích hợp **lưu trữ đám mây** và chia sẻ CV thông qua liên kết có thời hạn.
- Xây dựng **Dashboard** thống kê số lượng hồ sơ, lượt truy cập và trạng thái hệ thống.
- Ứng dụng AI hoặc hệ thống giám sát để phát hiện và cảnh báo các hành vi truy cập bất thường theo thời gian thực.

Tài liệu tham khảo

1) William Stallings (2020), *Cryptography and Network Security: Principles and Practice* (8th Edition), Pearson. *(Đây là cuốn giáo trình kinh điển thế giới về mật mã học, là cơ sở lý thuyết cho mã hóa lai).*
2) Charlie Kaufman, Radia Perlman, Mike Speciner (2002), *Network Security: Private Communication in a Public World* (2nd Edition), Prentice Hall.
3) NIST (National Institute of Standards and Technology) - *FIPS PUB 197: Advanced Encryption Standard (AES).* Đường dẫn: https://csrc.nist.gov/pubs/fips/197/final
4) NIST - *SP 800-38D: Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC. (Tài liệu chứng minh tính toàn vẹn Tamper-Evident của thuật toán AES-GCM).* https://csrc.nist.gov/pubs/sp/800/38/d/final
5) William Stallings, Lawrie Brown (2017), *Computer Security: Principles and Practice* (4th Edition), Pearson.